

2026년
전자금융기반시설
보안 취약점
평가기준 안내서 (배포용)

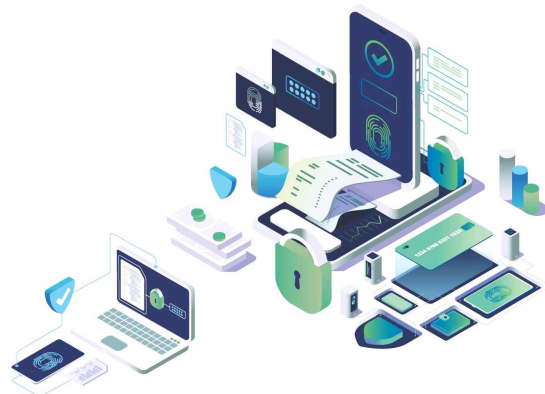


CONTENTS

1	평가 개요	1
2	평가 방법	2
3	평가 절차	3

참고

전자금융기반시설 보안 취약점 평가기준	7
----------------------------	---



1

평가 개요

- ❖ (개요) 「보안 취약점 분석·평가」란, 전자금융기반시설의 안전성과 신뢰성을 저해하는 사이버 위협에 대응하기 위해 잠재된 보안 위협을 찾고 이를 개선하기 위한 사전 예방 활동을 의미
- ❖ (평가대상) 금융회사 및 전자금융업자(이하 금융회사)는 관계 법령에서 정한 내용에 따라 전자금융 업무를 처리하기 위한 정보처리시스템(전자금융기반시설¹⁾)을 대상으로 취약점을 분석하고 이를 평가
- ❖ (평가주기) 공개용 홈페이지 점검은 연 2회 이상, 전자금융기반시설 점검은 연 1회 이상 평가



참고

전자금융기반시설 보안 취약점 분석·평가 관계 법령

【평가대상 및 절차 관련】

- 전자금융거래법 제21조의3 (전자금융기반시설의 취약점 분석·평가)
- 전자금융거래법 시행령 제11조의5 (전자금융기반시설 취약점 분석·평가의 내용), 제11조의6 (전자금융기반시설 취약점 분석·평가의 절차 및 방법 등)

【평가주기 관련】

- 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등)
- 전자금융감독규정시행세칙 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용)

※ 자세한 내용은 “국가법령정보센터(<http://www.law.go.kr>)” 또는 “전자금융감독규정 해설서(2025.8, 금융감독원)” 등을 참고

1) 전자금융기반시설 : 전자금융거래에 이용되는 정보처리시스템 및 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망을 의미

- 전자금융거래 : 금융회사 또는 전자금융업자가 전자적 장치를 통하여 금융상품 및 서비스를 제공(이하 “전자금융업무”라 한다)하고, 이용자가 금융회사 또는 전자금융업자의 종사자와 직접 대면하거나 의사소통을 하지 아니하고 자동화된 방식으로 이를 이용하는 거래를 말한다.
- 정보통신망 : 「전기통신사업법」 제2조제2호에 따른 전기통신설비를 이용하거나 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집·가공·저장·검색·송신 또는 수신하는 정보통신체제를 말한다.

2

평가 방법

본 안내서의 보안 취약점 분석·평가 방법 및 절차는 단순 참고용으로 평가전문기관에서 보유하고 있는 평가 방법 또는 금융회사 내부에서 정한 절차 및 기준을 직접 또는 변형하여 사용해도 무방함

❖ (평가 방법) 취약점 평가 수행 시 금융회사가 자체전담반을 구성하여 운영하는 방안과 외부 평가전문기관에 위탁하는 방안으로 구분

① 금융회사가 자체전담반을 구성하여 운영하는 방안

- 정보보호최고책임자를 포함한 5인 이상으로 자체전담반을 구성
- 자체전담반 구성 시 구성원 중 100분의 30 이상은 「정보보호산업의 진흥에 관한 법률 시행규칙」 제8조의 정보보호 전문서비스 기업 지정기준에서 정한 고급 기술 인력을 갖춘 자로 구성

② 금융회사가 평가전문기관에 위탁하는 방안

- 자체전담반을 구성하지 않을 경우 평가전문기관에 위탁 가능
- 평가전문기관은 「전자금융감독규정」 제37조의3(전자금융기반시설의 취약점 분석·평가 전문기관의 지정 등)에서 정의



참고

평가전문기관이란?

【관계 법령】

- 관계 법령에서 정한 평가전문기관으로, 전자금융기반시설에 대해 보안 취약점을 분석·평가할 경우, 정보보호전문서비스기업(약 29개, 2025.11.28. 기준) 또는 침해사고대응기관(금융보안원)에서 수행하도록 규정
- 전자금융감독규정 제37조의3(전자금융기반시설의 취약점 분석·평가 전문기관의 지정 등)
 1. 「정보통신기반 보호법」 제16조에 따라 금융분야 정보공유·분석센터로 지정된 자
 2. 「정보보호산업의 진흥에 관한 법률」 제23조에 따라 지정된 정보보호전문서비스 기업
 3. 침해사고대응기관
 4. 금융위원장이 지정하는 자

3

평가 절차

❖ (평가 절차) 보안 취약점 분석·평가 절차는 5단계로 구성되며, 단계별 주요 행위는 다음과 같음

평가 순서	평가 단계	주요 행위
①	사전 분석	평가계획 수립 및 업무현황 파악 등
②	취약점 분석	자산분석, 취약점 분석 등
③	취약점 평가	정보보호 분석·평가 지수 산출 등의 종합평가
④	대책 수립	발견된 취약점에 대한 보안대책 수립 등
⑤	사후 관리	발견된 취약점에 대한 조치계획 수립 등

① 「사전 분석 단계」에서의 주요 활동

- (계획 수립) 취약점 분석·평가를 실시하기 위해 수행 방법, 수행 절차, 소요 예산 등이 포함된 실행 계획을 수립
- (환경 파악) 평가대상에 대한 자산 현황, 업무 현황 등 시스템 운영 및 업무환경을 파악²⁾

2) 운영 및 업무환경 파악 : 필요에 따라 평가대상 시스템에 대한 보안성 검토 자료 또는 정보보호 정책 및 지침 등을 검토

② 「취약점 분석 단계」에서의 주요 활동

- (자산 분석) 자산이 업무 및 서비스에 미치는 영향을 파악하여 자산의 가치(중요도 등)를 산출하는 과정
 - (자산 분류) 보유 또는 운영하고 있는 자산의 업무 목적을 파악하여 업무 특성별로 자산을 분류
 - (자산 평가) 자산이 가지고 있는 정보의 성격, 자산의 가용성 수준을 복합적으로 평가하여 자산의 중요도를 결정
- 자산 중요도 : 각 자산에 대한 상대적 중요도를 기준으로 구분

[자산 중요도 분류 예시]

중요도	역할	점수 (등급)	서버	네트워크장비	정보보호시스템	영향
핵심 설비 (Core)	1그룹	4	- 중요DB 서버 등	- 인터넷연결구간 네트워크장비 등	- 침입차단시스템 (인터넷 차단) 등	- 금전적 손실 발생 등
	2그룹	3	- 인터넷뱅킹 서버 등	- 뱅킹서버구간 - 대외구간연결 등	- 침입차단시스템 (뱅킹/대외 등) - 암호화 장비 등	- 정보유출 등
	3그룹	2	- 메일,DNS 서버 등	- DMZ구간	- 침입탐지시스템	- 손실이 경미한 경우
지원설비 (Peripheral)		1	- 개발서버 기타서버	- 내부구간 네트워크장비		- 테스트 용도 등

- 정보 성격 : 위험성이 커지는 정보의 특성과 정보 자체가 가지고 있는 민감성을 고려하여 정보 성격을 구분
- 가용성 수준 : 업무 연속성 측면에서 업무 또는 서비스가 지속적으로 지원되어야 할 성질의 정도를 산정
- (취약점 분석) 자산의 중요도 및 업무 목적 등을 고려하여 자산에 내재된 보안 취약점을 분석

③ 「취약점 평가 단계」에서의 주요 활동

- (취약점 평가) 식별된 취약점이 금융회사에 미치는 영향을 파악하기 위해 각 취약점에 대한 위험도와 자산의 가치를 고려하여 분야별로 취약 수준을 평가
- (평가 지수 산출) 식별된 취약점에 대한 자산 가치, 취약점, 재발생률 등을 종합적으로 분석하여 금융회사의 전반적인 정보보호 관리 상황을 정량적으로 평가

④ 「대책 수립 단계」에서의 주요 활동

- (우선순위 산정) 식별된 취약점을 목록화하고 금융회사 업무 및 서비스 환경을 고려하여 조치 우선순위를 산정
- (보안대책 수립) 금융회사의 보안정책, 인터뷰 내용, 우선순위 산정 값 등을 활용하여 종합적인 보안대책을 수립

⑤ 「사후 관리 단계」에서의 주요 활동

- (이행 계획 수립) 보안대책 수립 내용을 참고하여 취약점에 대한 조치 이행 계획을 수립하고, 이행 결과를 최고경영자에게 보고
- (위험 수용) 식별된 취약점의 제거 또는 이에 상응하는 조치가 어려운 경우, 최고경영자의 승인이 필요하고 관련 취약점은 지속적인 관리 및 모니터링 필요

참고

전자금융기반시설 보안 취약점 평가기준



정보보호 관리체계

❖ 평가기준

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
1	정보보안 관련법규 위반에 관한 제재기준 및 절차수립 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)
2	정보기술(IT)부문계획 매년 수립 및 운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제36조의2(정보기술부문 계획서 제출 절차 등) 전자금융감독규정시행세칙 제3조(자체 보안성심의 기준 등)
3	정보처리시스템 관련 전담조직 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)
4	전자금융업무 관련 전담조직 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)
5	IT 아웃소싱(이하 'IT자회사'포함) 통제/관리 조직(인력포함) 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
6	정보보호최고책임자(CISO) 지정 여부	5	전자금융거래법 제21조의2(정보보호최고책임자 지정) 전자금융감독규정 제6조의2(정보보호최고책임자의 지정대상)
7	정기적으로 수행되는 임직원 정보보안 관련법규 준수여부 점검결과에 대한 임원(정보보호최고책임자, 최고경영자)보고 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)
8	정보보호 관련 사항을 심의·의결하는 정보보호위원회 설치 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조의2(정보보호위원회 운영)
9	정보보호위원회 구성의 적정성 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조의2(정보보호위원회 운영)
10	정보보호위원회 심의·의결 사항에 관한 적정성 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조의2(정보보호위원회 운영)
11	정보보호위원회 심의·의결 사항에 관한 임원(정보보호최고책임자, 최고경영자) 보고 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조의2(정보보호위원회 운영)
12	임직원의 정보보호역량 강화를 위한 교육계획 수립·시행 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)
13	전년도 교육계획 시행 결과 평가 및 금년도	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
	교육계획 반영 여부		전자금융감독규정 제8조(인력, 조직, 교육 및 예산)
14	건물 안전대책 및 출입통제 보안대책의 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제9조(건물에 관한 사항)
15	전산실 건물의 안정성을 위한 기준 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제10조(전원, 공조 등 설비에 관한 사항)
16	전산실의 재해, 출입, 접근통제 등 안전 및 보안 준수 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제11조(전산실 등에 관한 사항)
17	국내 본점을 둔 금융회사의 전산실 및 재해복구센터 국내 설치 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제11조(전산실 등에 관한 사항)
18	전산실내 무선통신망 설치 및 운용 금지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제11조(전산실 등에 관한 사항)
19	인가된 사용자 외 단말기 무단조작 방지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제12조(단말기 보호대책)
20	정보처리시스템 접속과 관련하여 사용자인가 여부를 확인할 수 있는 기록 유지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제12조(단말기 보호대책)
21	강화된 보호대책이 적용되는 중요단말기 지정 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제12조(단말기 보호대책)

ID	평가항목	위험도	[근거조항]
			전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
22	단말기에서 보조기억매체 등 접근통제(정보유출, 악성코드 감염 방지 등) 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제12조(단말기 보호대책)
23	전산자료 보유현황 관리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
24	전산자료 책임자 지정 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
25	전산자료 및 전산장비의 반출/반입 통제 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
26	보조기억매체 등 전산자료에 대한 안전지출 및 파기계획 수립 및 운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
27	보조기억매체 보유현황 및 관리실태에 관한 정기점검 및 책임자 확인 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
28	전산자료의 정기백업/소산 등 백업내역에 관한 기록 및 관리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
29	전산자료 중요도 분류기준 수립 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
30	주요 백업 전산자료에 대한 정기 검증 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
31	이용자 정보 조회 및 출력에 대한 통제 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책) 전자금융감독규정시행세칙 제2조의5(법인 이용자 정보의 사용에 대한 동의)
32	테스트 시 이용자 정보 사용금지(부하테스트 등의 불가피한 경우 이용자정보 변환 사용 및 테스트 종료즉시 삭제) 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책) 전자금융감독규정시행세칙 제2조의5(법인 이용자 정보의 사용에 대한 동의)
33	정보처리시스템 가동기록은 접속의 성공여부 상관없이 1년 이상 보존 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
34	단말기에 이용자 정보 등 주요정보 보관 금지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
35	단말기 공유 금지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
36	단말기 내 주요정보 보관 필요시, 관련 절차 수립 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
37	주요 정보처리시스템에 대한 운영 매뉴얼 등 작성 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)

ID	평가항목	위험도	[근거조항]
			전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
38	정상작동여부 확인을 위한 정보처리시스템 자원 상태의 감시, 경고 및 제어가 가능한 모니터링 시스템 설치 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)
39	시스템 통합, 전환 및 재개발시 정보처리시스템의 운영에 지장을 초래하지 않도록 통제절차 마련 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)
40	운영체제, 시스템 유틸리티 등의 긴급하고 중요한 보정(patch) 사항에 대하여는 즉시 보정 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)
41	중요도에 따른 운영체제(Operating System) 및 설정내용 등의 정기 백업, 원격안전지역 소산 및 백업자료 1년 이상 기록/관리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)
42	정보처리시스템의 운영체제 계정으로 로그인할 경우 이중인증 절차 적용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)
43	정보처리시스템 운영체제 계정에 대한 작업 내역 등 상시 모니터링 체계 수립 여부 및 이상징후 발생 시 통제 조치 시행 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조(정보처리시스템 보호대책)
44	정보처리시스템 사용 현황 및 추이 분석 등 정기적 실시 여부	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
			전자금융감독규정 제25조(정보처리시스템의 성능관리)
45	전자금융기반시설의 취약점 분석·평가는 연 1회 이상(홈페이지에 대해서는 6개월에 1회 이상) 실시 여부	5	전자금융거래법 제21조의3(전자금융기반시설의 취약점 분석·평가) 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) 전자금융감독규정시행세칙 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용)
46	취약점 분석·평가결과에 따른 취약점 제거 또는 이에 상응하는 조치 시행 여부	5	전자금융거래법 ○ (전자금융거래법) 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) 전자금융감독규정시행세칙 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용)
47	취약점 제거 또는 이에 상응하는 조치가 불가능한 경우 최고경영자 승인 취득 여부	5	전자금융거래법 ○ (전자금융거래법) 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) 전자금융감독규정시행세칙 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용)
48	취약점 분석·평가결과에 대한 이행계획 수립 여부 및 최고경영자 보고 여부	5	전자금융거래법 ○ (전자금융거래법) 전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등) 전자금융감독규정시행세칙 제7조의2(전자금융기반시설의 취약점 분석·평가의 내용)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
			내용)
49	해킹 등을 방지하기 위한 정보보호시스템 설치 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
50	내부 단말기의 정보보호시스템을 우회한 인터넷 등 외부 통신망(무선통신망 포함) 접속 차단 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의3(망분리 적용 예외)
51	내부통신망과 연결된 내부 업무용시스템이 인터넷(무선통신망 포함) 등 외부통신망과 분리·차단 및 접속 금지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의3(망분리 적용 예외)
52	내부통신망에서의 파일 배포기능 이용 시 파일 무결성 검증 수행 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
53	전산실 내에 위치한 정보처리시스템과 해당 정보처리시스템의 운영, 개발, 보안 목적으로 직접 접속하는 단말기가 인터넷 등 외부통신망으로부터 물리적으로 분리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의3(망분리 적용 예외)
54	정보보호시스템에 최소한의 서비스번호와 기능 적용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)

ID	평가항목	위험도	[근거조항]
			전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
55	정보보호시스템의 업무목적 이외 기능 및 프로그램 제거 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)
56	정보보안 정책 승인 및 적용 시, 정책 등록,변경,삭제 내용에 대한 보관 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)
57	정보보호시스템 원격관리 차단 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)
58	정보보호시스템 원격관리 이용 시, 원격 접속에 관한 보안대책 수립 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)
59	정보보호시스템 작동상태 모니터링 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)
60	정보보호시스템에 대한 백업 및 복구절차 수립 및 시행 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책) 전자금융감독규정시행세칙 제2조의6(정보보호시스템 운영)
61	정보보호시스템 책임자 지정/운영 및	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
	운영결과 1년 이상 보존 여부		전자금융감독규정 제15조(해킹 등 방지대책)
62	무선통신망 이용 업무의 정보보호최고책임자 승인 및 사전 지정 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
63	사용자인증, 암호화 등 무선통신망 보안대책 수립	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
64	금융회사 내부망에 연결된 정보처리시스템이 지정 된 업무 용도와 사용 지역(zone) 이외의 무선통신망에 접속하는 것을 차단하기 위한 차단시스템 구축 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
65	무선통신망 실시간 모니터링체계 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
66	악성코드 감염·확산 방지, 피해 최소화 및 복구를 위한 대책을 수립·운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제16조(악성코드 감염 방지대책)
67	중요 단말기의 악성코드 감염 여부 정기 점검 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제12조(단말기 보호대책)
68	공개용 웹서버의 DMZ구간내 설치 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
69	공개용 웹서버를 네트워크 및 웹 접근 제어	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
	수단으로 보호 여부		전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
70	공개용 웹서버 접근 사용자계정을 업무관련자로 제한 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
71	공개용 웹서버에 접근할 수 있는 사용자계정은 아이디 비밀번호 이외에 추가인증수단 적용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
72	공개용 웹서버 제공이외 다른 서비스 및 시험/개발도구 등의 사용 제한 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
73	홈페이지에 자료를 게시하는 절차 및 내부통제 방안 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
74	개인정보의 유출 및 위/변조를 방지하기 위한 보안조치 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제17조(홈페이지 등 공개용 웹서버 관리대책)
75	단말기에서 음란, 도박 등 업무와 무관한 프로그램 및 인터넷사이트에 대한 접근 통제 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
76	내/외부 IP주소의 인터넷 접속내용 1년이상 별도 기록/보관 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제18조(IP주소 관리대책)
77	암호프로그램 담당자 지정 여부	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
			전자금융감독규정 제19조(암호프로그램 및 키 관리 통제)
78	암호프로그램의 비담당자 이용에 관한 통제 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제19조(암호프로그램 및 키 관리 통제)
79	암호프로그램에 대한 원시프로그램 별도 보관 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제19조(암호프로그램 및 키 관리 통제)
80	암호 및 인증시스템에 적용되는 키에 대하여 주입/운용/갱신/폐기에 대한 절차 및 방법 마련 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제19조(암호프로그램 및 키 관리 통제)
81	사용자 인증수단 개인별 부여 및 최소한의 접근권한 부여 등 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
82	사용자 인사조치 시 지체없이 해당 사용자 계정 삭제, 사용 중지, 공동 사용 계정 변경 등 정보처리시스템 접근 통제 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
83	사용자 계정 공동사용 시 개인별 사용내역에 대한 기록저장 및 관리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
84	정보처리시스템 관리자에 대한 적절한 통제장치 마련 및 운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)

ID	평가항목	위험도	[근거조항]
			전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
85	정보처리시스템 관리자 주요업무관련행위의 책임자 이중 확인 및 모니터링 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)
86	사용자 비밀번호에 관한 주기적 변경 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제19조의2(사용자 인증수단 관리)
87	사용자 비밀번호 보관시 암호화 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제19조의2(사용자 인증수단 관리)
88	사용자 비밀번호 연속 입력 오류 시 즉시 접속 차단 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제19조의2(사용자 인증수단 관리)
89	정보처리시스템 및 전산자료에 보관하고 있는 이용자 비밀번호 암호화 보관 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
90	이용자 비밀번호 조회 금지 및 불가피한 경우 조회사유 및 내용 기록 관리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
91	이용자 비밀번호 등록 시 제3자가 쉽게 유추 할 수 있는 비밀번호의 설정 금지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
92	이용자 비밀번호가 일정횟수 입력오류 시 해당비밀번호 이용거래에 대한 즉시 중지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
93	이체비밀번호 등 동일한 비밀번호가 다양한 형태의 전자금융거래에 공통으로 이용되는 경우 입력오류 횟수는 이용되는 모든 전자금융거래에 대한 통산 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
94	이용 중지된 이용자 비밀번호의 재부여 또는 거래재개 시 본인확인 절차 적용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
95	신규거래, 비밀번호 변경, 이체 신청 등 비밀번호를 등록/사용하는 경우 사전에 신청서등에 기재 금지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
96	비밀번호를 등록·사용하는 경우 핀패드 등 보안장치를 이용 또는 사후에 전자적 장치를 이용하여 직접 입력하는 방식의 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
97	전산원장 변경을 위한 변경절차 수립 및 운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
98	전산원장 변경절차에 변경 대상 및 방법 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
99	전산원장 변경절차에 변경 권한자 지정 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
100	전산원장 변경 절차에 변경 전후 내용 자동기록 및 보존 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
101	전산원장 변경절차에 변경내용의 정당여부에 대한 제3자 확인 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
102	대차대조표 등 중요자료 계상액과 각종 보조부/거래기록/전산원장파일의 계상액에 대한 상호일치여부에 대한 전산시스템을 통한 주기적인 확인 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
103	전산원장 불일치 원인과 조치 내용을 전산자료형태로 5년간 보존 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
104	중요원장의 조회, 수정, 삭제, 삽입한 작업자와 작업내용 기록 및 5년간 보존 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제27조(전산원장 통제)
105	사고위험도가 높은 거래에 대한 전산시스템 기반의 책임자 이중확인 절차 적용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제28조(거래통제 등)
106	전산원장, 주요정보, 이용자정보 등이 저장된 정보처리시스템 중요작업에 대한 책임자 이중확인 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제13조(전산자료 보호대책)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
107	일괄작업(batch) 수행을 위한 절차 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제30조(일괄작업에 대한 통제)
108	사업 추진 시 내부통제 기준 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제20조(정보처리시스템 구축 및 전자금융거래 관련 사업 추진)
109	계약 체결 시 내부통제 절차 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제21조(정보처리시스템 구축 및 전자금융거래 관련 계약)
110	정보처리시스템 감리 지침 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제22조(정보처리시스템 감리)
111	정보기술부문의 내부통제를 위한 직무분리 기준 수립/운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조의3(직무의 분리)
112	프로그램 등록/변경/폐기 방법에 관한 절차 수립 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제29조(프로그램 통제) 전자금융감독규정시행세칙 제2조의7(프로그램 통제)
113	신규 업무 및 표준 제정 시 보안성 심의 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제36조(자체 보안성심의) 전자금융감독규정시행세칙 제3조(자체 보안성심의 기준 등)
114	업무지속성 확보방안에 상황별 대응절차	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
	포함 여부		전자금융감독규정 제23조(비상대책 등의 수립·운용)
115	업무지속성 확보방안에 백업 또는 재해복구센터를 활용한 재해복구계획 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
116	업무지속성 확보방안에 비상대응조직의 구성 및 운용 포함	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
117	업무지속성 확보방안에 입력대행, 수작업 등의 조건 및 절차 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
118	업무지속성 확보방안에 모의 훈련의 실시 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
119	업무지속성 확보방안에 유관기관 및 관련업체와의 비상연락체계 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
120	업무지속성 확보방안에 보고 및 대외통보의 범위와 절차 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
121	업무지속성 확보대책을 매년 1회 이상 점검 및 최신상태 유지 및 관리 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
122	정보처리시스템 및 데이터저장장치 등 주요 전산장비의 이중화 구축 또는 예비장치 확보 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
123	주전산센터와 일정거리 이상 떨어진 안전장소에 재해복구센터 구축 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
124	적정한 규모와 인력을 구비한 재해복구센터 구축 및 운영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
125	재해복구 목표시간 내 재해복구 가능 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
126	매년 1회 이상 재해복구센터로 재해복구전환훈련 실시 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
127	위기대응 행동매뉴얼 또는 비상대책 수립 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
128	위기대응 행동매뉴얼 또는 비상대책에 업무지속성 확보대책의 반영 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운용)
129	연 1회 해킹, 디도스공격 등 침해사고 대응 및 복구훈련 실시와 침해사고대응기관에 제출 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제37조의6(침해사고대응기관 지정 및 업무범위 등)
130	금융위원회 주관 금융분야 합동비상대응훈련 실시 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제24조(비상대응훈련 실시)

ID	평가항목	위험도	[근거조항]
			전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙 , 2025. 2. 3.)
131	전자금융거래 시 암호화 통신 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조(전자금융거래 시 준수사항)
132	전자금융거래 시 비대면 전자금융거래를 허용하지 않는 계좌개설 서비스를 제공할 수 있도록 시스템 구축 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조(전자금융거래 시 준수사항)
133	전자금융거래 시 중요거래정보에 대한 문자메시지 및 이메일서비스를 제공할 수 있도록 시스템 구축 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조(전자금융거래 시 준수사항)
134	전자금융거래 시 전자금융거래에 사용되는 접근매체의 본인 실명증표 확인 후 교부 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조(전자금융거래 시 준수사항)
135	전자금융거래에 관한 거래인증수단 채택시 안전성, 보안성, 이용편의성 등을 충분히 고려 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조(전자금융거래 시 준수사항)
136	전자금융거래의 종류·성격·위험수준 등을 고려한 인증방법 사용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의2(인증방법 사용기준)
137	이용자 비밀번호 유출위험 및 관리에 관한 사항 공지 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제35조(이용자 유의사항 공지)
138	IT외부주문 업무에 대한 업무적정성 검토 여부	5	전자금융거래법 제21조(안전성의 확보의무)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
			전자금융감독규정 제8조(인력, 조직 및 예산)
139	IT외부주문 계약 체결시 계약내용의 적정성 검토 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직 및 예산)
140	외부주문 등의 입찰·계약·수행·완료 등 각 단계별로 금융감독원장이 정하는 보안관리방안 준수 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준) 전자금융감독규정시행세칙 제9조의2(외부주문등에 대한 기준)
141	외부주문 시 내부통제방안 수립 및 운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직 및 예산)
142	외부주문 시 정보처리시스템 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치·운영 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
143	외부주문 시 금융기관과 이용자간 암호화정보 해독 및 원장 등 중요 데이터 변경 금지 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
144	외부주문 시 계좌번호, 비밀번호 등 이용자 금융정보 보관 및 유출 금지 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
145	외부주문 시 접근매체 위/변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)

ID	평가항목	위험도	[근거조항]
			전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
146	외부주문 시 금융기관과 전자금융보조업자간의 접속은 전용회선 사용 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
147	외부주문 시 정보처리시스템 장애 등 서비스 중단에 대비한 비상대책 수립 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
148	외부주문 시 중요전산자료의 백업자료 보존 및 백업설비 확보 등 백업대책 수립 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
149	외부주문 사항에 대해 연1회 이상 재무건전성 평가 및 주요 경영활동 상시모니터링 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
150	외부주문 사항에 대해 연1회 이상 서비스 품질수준 평가 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
151	외부주문 사항에 대해 사전 동의 없는 재위탁, 계약업체 변경 금지(사전 동의시 계약서 기재사항 포함) 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
152	외부주문 사항에 대해 위탁회사가 전자금융거래정보 보호와 관련된 전산장비·소프트웨어 개발,운영,유지관리	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
	업무 재위탁 시, 금융거래 정보 변경사항에 대해 위탁회사 또는 원수탁업자가 이를 관리, 통제할 수 있는 절차 마련 여부		
153	외부주문 사항에 대해 위탁된 금융거래정보가 위탁회사의 전산실 내 관리 및 보관 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
154	외부주문 시 업무 수행인력에 대한 사전 신원조회 실시, 대표자 신원보증서 징구, 인력변경시 인수인계에 관한사항 등 업무수행인력에 관한 관리방안 수립 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준)
155	외부주문 시 자체 보안성 검토 및 정기 보안점검 실시 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제60조(외부주문등에 대한 기준) 전자금융감독규정시행세칙 제9조의2(외부주문등에 대한 기준)
156	전자금융 사고 관련 사고의 유형 분류, 영향도 등이 포함된 절차를 마련, 운영 여부	5	전자금융거래법 제21조의5(침해사고의 통지 등) 전자금융감독규정 제37조의5(정보기술부문 및 전자금융 사고보고) 전자금융감독규정시행세칙 제7조의4(정보기술부문 사고보고)
157	전자금융 사고 발생 시 지체없이 금융감독원장 보고 여부	5	전자금융거래법 제21조의5(침해사고의 통지 등) 전자금융감독규정 제37조의5(정보기술부문 및 전자금융 사고보고) 전자금융감독규정시행세칙 제7조의4(정보기술부문 사고보고)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
158	해킹 등 전자적 침해행위로 인한 피해 발생시 즉시 대처할 수 있도록 적절한 대책 수립 및 운용 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제15조(해킹 등 방지대책)
159	전자금융사고 시 책임이행을 위한 보험 등 가입 여부	5	전자금융거래법 제9조(금융회사 또는 전자금융업자의 책임) 전자금융감독규정 제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준)
160	전자금융사고시 보상한도설정의 적정성 여부	5	전자금융거래법 제9조(금융회사 또는 전자금융업자의 책임) 전자금융감독규정 제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준)
161	전자금융사고 시 책임이행을 위한 준비금 관리 및 지급에 관한 내부절차 수립 및 운영 여부	5	전자금융거래법 제9조(금융회사 또는 전자금융업자의 책임) 전자금융감독규정 제5조(전자금융사고 책임이행을 위한 보험 등의 가입에 관한 기준)
162	위기대응 행동매뉴얼 또는 비상대책에 따라 연 1회의 비상대응훈련을 실시하고 그 결과를 금융위원회에 보고하는지 여부 확인	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제24조(비상대응훈련 실시)
163	침해사고 인지 시 24시간 이내 금융위원회 보고 여부	5	전자금융거래법 제9조(금융회사 또는 전자금융업자의 책임) 전자금융감독규정 제37조의4(침해사고 통지의 방법)
164	오픈뱅킹 운영기관에서 정한 기준에 따라	5	전자금융거래법 제21조의3(전자금융기본시설의 취약점 분석·평가)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
	오픈뱅킹 서비스 보안 점검 실시 및 이행점검 실시 여부		전자금융감독규정 제37조의2(전자금융기반시설의 취약점 분석·평가 주기, 내용 등)
165	전자금융거래기록 생성 및 보존·파기 관리 여부	5	전자금융거래법 제22조(전자금융거래기록의 생성·보존 및 파기)
166	클라우드컴퓨팅서비스 이용계약 신규 체결 시 금융감독원 보고 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)
167	클라우드컴퓨팅서비스 제공자 변경(합병, 재위탁 등) 시 금융감독원 보고 여부	5	전자금융거래법 제40조(외부주문등에 대한 감독 및 검사) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)
168	클라우드컴퓨팅서비스 제공자의 서비스 품질 미이행 시 대응 계획 보고 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)
169	클라우드컴퓨팅서비스 이용 업무의 중요도 평가 기준 수립 및 시행 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)
170	클라우드컴퓨팅서비스 제공자의 건전성 및 안전성에 대한 평가 실시 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)

ID	평가항목	위험도	[근거조항] 전자금융감독규정 (금융위원회고시 제2025-4호, 2025. 2. 5.) 전자금융감독규정시행세칙 (금융감독원세칙, 2025. 2. 3.)
171	클라우드컴퓨팅서비스 업무 연속성 계획 수립 및 안전성 확보 조치 수립 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)
172	클라우드컴퓨팅서비스 정보보호위원회 심의 및 의결을 통해 평가 결과 승인 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제14조의2(클라우드컴퓨팅서비스 이용절차 등) 전자금융감독규정시행세칙 제2조의4(클라우드컴퓨팅서비스의 보고)
173	업무지속성 확보방안에 비상지원인력의 확보 및 운영 포함 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제23조(비상대책 등의 수립·운영)
174	이용자 비밀번호 변경 시 본인확인 절차 수행 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제34조의3(이용자 비밀번호 관리)
175	정보기술 및 정보보호 분야별 전문 인력과 충분한 예산 확보 여부	5	전자금융거래법 제21조(안전성의 확보의무) 전자금융감독규정 제8조(인력, 조직, 교육 및 예산)

가상화 시스템 관리체계

❖ 평가기준

ID	평가항목	위험도	상세설명
1	정기적인 가상화 인스턴스(가상머신, 컨테이너) 식별 여부	5	o 정기적인 가상화 인스턴스(가상머신, 컨테이너) 식별 여부를 점검
2	가상화 인스턴스(가상머신, 컨테이너)의 생성, 변경, 회수 등에 관한 승인절차 수립 및 이행	3	o 가상화 인스턴스(가상머신, 컨테이너) 생성, 변경, 회수 등에 관한 승인 절차 수립 및 이행 여부를 점검
3	가상화 인스턴스(가상머신, 컨테이너) 변경에 대한 기록 관리	3	o 가상화 인스턴스(가상머신, 컨테이너)의 변경(생성, 이동, 삭제, 복사 등)에 관한 기록 관리 여부를 점검
4	가상화 인스턴스(가상머신, 컨테이너)의 보안 등급에 따른 책임자 지정	5	o 가상화 인스턴스(가상머신, 컨테이너)의 보안 등급(중요도) 측정 및 그에 따른 책임자 지정 여부를 점검
5	가상머신 구축시 표준 이미지 사용	3	o 보안 취약점을 제거한 표준 이미지(Golden Image) 생성 및 배포 여부를 점검
6	주기적인 표준 이미지 보안 검증 수행	3	o 표준 이미지(Golden Image)에 대한 주기적인 보안 점검 수행 여부를 점검
7	컨테이너 구성 파일에 대한 사전 보안 검증 수행	3	o 컨테이너 구성 파일(매니페스트 파일, 도커파일 등)의 사전 보안 점검 수행 여부를 점검
8	시스템 가동기록 보관	5	o 클라우드 시스템에 대한 가동기록 보관(1년 이상) 여부를 점검

ID	평가항목	위험도	상세설명
9	시스템에 대한 성능 및 용량 모니터링	5	○ 가상 시스템 및 가상자원에 대한 성능·용량 모니터링 및 사용 현황·추이 분석 수행 여부를 점검
10	시스템 운영 매뉴얼 작성	5	○ 클라우드 시스템 운영매뉴얼 작성 및 주기적 갱신 여부를 점검
11	장애 발생시 장애상황기록부 작성	5	○ 장애 발생 시 장애상황기록부(일시, 내용, 조치사항 등) 작성 및 보관 여부를 점검
12	시스템 정기 백업 및 보관 여부	5	○ 가상화 인스턴스 및 가상 네트워크 접근통제 정책의 정기 백업과 안전지역 소산 및 기록 관리(1년 이상) 여부를 점검
13	재해 또는 장애발생 시 복구를 위한 별도 구간 확보	5	○ 비상시를 대비한 재해 복구 센터 또는 백업센터 등 별도 네트워크 구간 마련 여부를 점검
14	시스템 접근 시 강화된 보호대책이 적용된 단말기를 통한 접속	5	○ 강화된 보호대책이 적용된 단말기를 통한 클라우드 시스템 접근 여부를 점검
15	가상네트워크 접근통제 정책에 대한 변경통제 절차 수립	5	○ 가상 네트워크 접근통제 정책의 등록, 변경, 삭제 내용에 대한 보관 여부를 점검
16	소프트웨어 및 하드웨어 지원 서비스가 종료(EoS)된 노후장비 교체	5	○ 지원이 종료(End of Service)된 노후 장비 존재 여부를 점검
17	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	○ 최신 보안 패치 및 벤더 권고사항 이행 여부를 점검
18	시스템의 이중화 구성 여부	5	○ 클라우드 관리 플랫폼, 하이퍼바이저 등 클라우드 시스템의 이중화(클러스터 구성) 구성 여부를 점검

ID	평가항목	위험도	상세설명
19	업무 특성별 가상 네트워크 구간 분리 구성	5	o 업무 특성별로 가상 네트워크 구간을 적절하게 분리하고 있는지 점검
20	클라우드 시스템과 가상자산 간 IP 분리 구성	5	o 클라우드 시스템과 가상화 인스턴스 간 IP 분리 구성 여부를 점검

클라우드 관리체계

❖ 평가대상

A	B
AWS	Azure

❖ 평가기준

ID	A	B	평가항목	위험도	상세설명
1	o	o	통신구간 암호화 적용 여부	5	o HTTP 요청 거부 설정 활성화 및 통신구간 암호화 적용 여부를 점검
2		o	취약한 HTTPS 프로토콜 허용	3	o 취약한 버전의 암호 프로토콜(TLS 1.2 미만) 허용 여부를 점검
3		o	앱 배포 시 취약한 프로토콜 허용	5	o 앱 배포 시 FTP 기반 배포 허용 여부를 점검
4		o	소스코드 저장소 접근 시 안전한 네트워크 경로 사용	5	o 애플리케이션 소스코드 저장소 접근 시 사설 네트워크 경로 사용 여부를 점검
5	o	o	가상자원에 대한 퍼블릭 액세스 허용	5	o 가상자원의 퍼블릭 액세스 차단 설정 활성화 여부를 점검
6	o	o	업무 목적 기반 네트워크 분리 및 접근 통제	5	o 개발·운영 등 목적에 맞는 네트워크 분리 구성 및 접근통제 설정 여부를 점검
7	o	o	네트워크 접근 제어 설정의 최소 권한 적용	5	o 네트워크 보안 설정(방화벽, 보안그룹 등)의 최소 권한 원칙 준수 및 과도한 접근 권한 허용 여부를 점검

ID	A	B	평가항목	위험도	상세설명
8	o	o	네트워크 설정 변경 이력 추적	4	o 네트워크 구성요소(VPC, NAT 등)의 생성·변경·삭제 이력에 대한 감사 로그 기록 여부를 점검
9	o	o	확장 가능한 데이터 수명주기 관리 정의	3	o 데이터 수명주기 정책 정의 및 단계별(암호화, 이동, 파기 등) 자동화 점검 체계 마련 여부를 점검
10	o	o	데이터 민감도에 따른 보호 조치	3	o 데이터 민감도에 따른 보호 조치 차등 적용 및 설정 오류 탐지 모니터링 체계 운영 여부를 점검
11	o	o	데이터 분류 체계 수립	3	o 데이터 분류체계(종류, 민감도, 위치, 주기 등) 정의 및 수준별 보호 조치·접근 정책 수립 여부를 점검
12	o	o	보안 로그의 안전한 저장 및 장기 보존 설정	5	o 감사 및 보안 로그의 안전한 저장소 보관 및 무결성·접근 통제 적용 여부를 점검
13	o	o	접근 로그 수집 기능 활성화 여부	5	o 시스템·네트워크 경계의 접근 로그 기능 활성화 및 사용자 요청·행동 추적 가능 여부를 점검
14	o	o	보안 로그 및 이벤트 상관 관계 분석	3	o 로그 상관관계 분석을 통한 위협 이벤트 파악 및 대응 체계 구축 여부를 점검
15	o	o	가상자원 생성·변경·삭제 행위 추적	5	o 가상자원의 생성·변경·삭제 행위에 대한 추적 로그 수집 여부를 점검
16		o	저장소 임의 삭제 방지 대책 적용 여부	4	o 중요 정보 저장소의 의도치 않은 삭제 방지 대책 적용 여부를 점검

ID	A	B	평가항목	위험도	상세설명
17	○	○	삭제된 저장소 내 데이터 복원 기능 활성화 여부	5	○ 중요 정보 저장소 삭제 시 데이터 복원을 위한 복원 기능 활성화 여부를 점검
18	○	○	API 호출 이력 행위 추적	5	○ API 호출 이력(호출자, 시점, 대상 등)의 추적 및 기록 관리 여부를 점검
19	○	○	가상자원 상태 및 장애 모니터링 기능 적용	5	○ 가상자원 상태·트래픽·장애 상황에 대한 실시간 모니터링 기능 확보 여부를 점검
20	○	○	강화된 이미지 기반 컴퓨팅 리소스 제공	5	○ 신뢰할 수 있는 이미지를 활용한 컴퓨팅 자원 구성 및 이미지·종속성 무결성 검증 여부를 점검
21	○	○	소프트웨어 및 이미지 무결성 확인 체계 구축	5	○ 모든 소프트웨어 및 이미지의 검증된 출처 확인 및 무결성 검증(공급자 또는 자체 서명) 수행 여부를 점검
22	○	○	가상 머신 이미지 또는 템플릿이 외부에 노출되지 않도록 설정	5	○ 가상 머신 이미지 또는 템플릿의 외부 노출 여부를 점검
23	○	○	업무상 불필요한 가상자원 존재	3	○ 업무상 불필요하거나 장기간 사용되지 않는 가상자원의 존재 여부를 점검
24	○	○	운영체제 및 플랫폼 구성요소에 대한 보안 업데이트 정책 설정	4	○ 운영체제 및 소프트웨어 구성요소 보안 업데이트를 위한 정책 설정 여부를 점검
25	○	○	서비스 지원이 종료된(EoS) 런타임 교체 여부	5	○ 서비스 지원이 종료된(EoS) 버전의 런타임 사용 여부를 점검

ID	A	B	평가항목	위험도	상세설명
26	o	o	암호화 키 생성·보관·교체·폐기 관리 정책 수립	5	o 암호키의 생성·저장·변경·폐기에 대한 안전한 관리 방안 수립 여부를 점검
27	o	o	안전한 암호화 알고리즘 적용	5	o 적용된 암호화 알고리즘의 안전한 표준(검증된 알고리즘) 부합 여부를 점검
28	o	o	자격증명 주기적인 갱신	5	o 자격증명(키, 비밀번호 등)의 암호화·최소권한 관리, 자동 로테이션 및 코드 내 포함 여부 검출 체계 운영을 점검
29	o	o	암호화 대상 자원 식별 및 암호화 적용	5	o 암호화가 필요한 데이터가 저장된 가상자원에 대한 암호화 수행 여부를 점검
30	o		디스크 볼륨 생성 시 암호화 설정 여부	3	o 디스크 볼륨 생성 시 암호화 적용 설정의 활성화 여부를 점검
31	o		디스크 볼륨 암호화 적용 여부	5	o 디스크 볼륨의 암호화 적용 여부를 점검
32	o		스냅샷 암호화 적용 여부	5	o 스냅샷의 암호화 적용 여부를 점검
33	o		이미지 암호화 적용 여부	5	o 이미지의 암호화 적용 여부를 점검
34	o		DB 인스턴스 암호화 적용 여부	5	o DB 인스턴스에 대한 암호화 적용 여부를 점검
35	o	o	초기화 스크립트 내 인증정보 또는 비밀번호 미포함 여부	5	o 컴퓨팅 인스턴스 초기화 데이터 및 스크립트 내 인증정보·비밀값 포함 여부를 점검
36	o	o	환경변수 내 중요정보 암호화 적용 여부	5	o 가상자원 환경변수 내 중요정보(비밀번호, API Key 등)의 암호화 저장 여부를 점검

ID	A	B	평가항목	위험도	상세설명
37	o	o	비밀번호 정책 수립 및 로그인 제한 설정	5	o 비밀번호 설정 상태 및 복잡도 정책의 적정 적용 여부를 점검
38	o	o	가상자원 접속 보안 인증 절차 적용	5	o 가상자원 접속 시 안전한 인증 방안(인증서 기반 접속, 권한 검증 등) 적용 여부를 점검
39	o	o	클라우드 자원에 접근 가능한 계정에 추가인증수단 적용 여부	5	o 클라우드 접근 계정에 대한 이중 인증(OTP, 이메일, 바이오 인증 등) 설정 여부를 점검
40	o	o	최고 권한 계정(root 등) 보호 및 사용 제한	5	o 루트 계정의 접근 제한 및 비상 용도 외 사용 금지, 모니터링 및 통제 여부를 점검
41	o		관리자 계정의 액세스 키 삭제 여부	5	o 관리자(root) 계정의 액세스 키 삭제 여부를 점검
42	o	o	API 자격 증명 다중 발급 방지 여부	3	o API 자격 증명을 다중 보유한 식별자(계정, 애플리케이션 등) 존재 여부를 점검
43	o	o	API 자격 증명의 정기적 갱신 이행 여부	3	o API 자격 증명의 정기적 갱신 정책 수립 및 이행 여부를 점검
44	o	o	조직 내부 자원 안전 공유	2	o 리소스 공유 시 보안 정책 준수 및 통합적·일관적 구성 여부를 점검
45	o	o	그룹 및 속성 기반 권한 부여 및 최소 권한 정책 적용	3	o 사용자 그룹 및 속성 기반의 접근 권한 설정과 최소 권한 원칙 구현 여부를 점검
46	o	o	웹 기반 웹 환경 권한 통제 여부	4	o 클라우드 웹 기반 웹 환경에 대한 권한 통제 여부를 점검

ID	A	B	평가항목	위험도	상세설명
47	○	○	사용 권한 정기 검토 및 불필요 권한 제거 여부	3	○ 권한 정책의 주기적 검토 및 불필요한 계정·권한 제거 등 최소 권한 유지 방안 마련 여부를 점검
48	○	○	외부/계정 간 리소스 공유 및 접근 권한	4	○ 외부 및 타 계정 공유 리소스의 주기적 분석과 불필요한 접근 설정 여부를 점검
49		○	테넌트 간 개체 복제 허용 방지	3	○ 테넌트 간 복제 허용 설정 활성화 여부를 점검
50	○	○	컨테이너 작업에서 호스트 네트워크 사용 시 권한 상승 제한 여부	5	○ 호스트 네트워크 모드 사용 시 권한 상승 제한 및 호스트 리소스 접근 차단 설정 여부를 점검
51	○	○	제3자 접근 시 임시 권한 부여 및 최소 권한 적용	5	○ 제3자 리소스 공유 시 단기성 권한 부여 및 외부 ID 식별자를 통한 최소 권한 적용 여부를 점검
52	○	○	워크로드 팀의 보안 책임 부여 및 자율적 보안 수행 체계	1	○ 워크로드별 보안 책임 부여 및 자율적 보안 결정을 위한 프로그램 운영 여부를 점검
53	○	○	보안 통제 목표 식별 및 검증	3	○ 보안 통제 목표 정의 및 통제 효과 평가, 자동화 정책 기반의 검증 수행 여부를 점검
54	○	○	위협 모델링을 통한 보안 위험 식별 및 대응	3	○ 위협 모델링 수행을 통한 위협 식별 및 예방·탐지·대응 통제 수립 및 갱신 여부를 점검
55	○	○	최신 보안 위협 및 권고사항 반영	5	○ 보안 위협 인텔리전스 수집 기반의 자동화된 탐지 및 대응 체계 적용 여부를 점검

ID	A	B	평가항목	위험도	상세설명
56	○	○	중앙 관리 도구 또는 에이전트를 활용한 인스턴스 관리	3	○ 클라우드 관리 도구 또는 에이전트를 활용한 컴퓨팅 인스턴스의 중앙 관리 여부를 점검
57	○	○	보안 관리 범위 최소화	1	○ 관리형 서비스 및 자동화 기능을 활용한 보안 관리 범위 축소 및 보안 부담 완화 구조 설계 여부를 점검
58	○	○	표준 보안 통제 자동화 적용	2	○ 보안 정책·통제의 코드화 및 CI/CD 파이프라인을 통한 자동 테스트·배포 구성 여부를 점검
59	○	○	개발 및 배포 전 과정에서 보안 테스트 자동화	3	○ 보안 테스트 자동화 도구를 통한 개발 및 배포 전 과정의 보안 검증 여부를 점검
60	○		실행 코드 무결성 검증 절차 운용 여부	5	○ 서명 기능을 활용한 가상자원 실행 코드의 무결성 검증 절차 구축 및 운용 여부를 점검
61	○	○	컴퓨팅 자원 보호 작업(스캔, 패치, 대응)의 자동화	3	○ 컴퓨팅 자원의 패치·스캔·탐지 자동화 및 비정상 상황 시 자동 조치 구조 구성 여부를 점검
62	○	○	취약점 관리 수행	5	○ 소스코드·종속성·인프라에 대한 자동화된 취약점 스캔 및 위험도 기반 패치 관리 체계 운영 여부를 점검
63	○	○	정기적인 침투 테스트 수행	5	○ 정기적인 침투 테스트 수행 및 결과에 따른 취약점 개선 여부를 점검
64	○		컴퓨팅 인스턴스에서 IMDSv1 비활성화 여부	5	○ IMDSv2 활성화 여부를 점검

ID	A	B	평가항목	위험도	상세설명
65	o	o	보안 사고 대응을 위한 체계 구축	2	o 보안 사고 대응을 위한 내·외부 인력의 역할 및 연락 체계 정의와 정기 업데이트 여부를 점검
66	o	o	보안 사고 대응 계획 문서화 및 정기 점검	2	o 사고 대응 프로세스 문서화 및 단계별 역할·책임의 주기적 점검 및 개선 여부를 점검
67	o	o	사고 대응 시나리오 개발 및 테스트	2	o 사고 유형별 대응 시나리오(플레이북) 수립 및 정기 모의훈련·대응 테스트 실시 여부를 점검
68	o	o	사고 발생 시 재발 방지 체계 구축	2	o 사고 원인 분석 및 재발 방지 대책의 문서화·공유와 보안 정책 개선 피드백 체계 마련 여부를 점검
69	o	o	사전 접근 권한 부여	2	o 사고 대응 인력에 대한 사전 권한 부여 또는 즉시 부여 프로세스 마련 여부를 점검
70	o	o	침해사고 조사 분석 역량 체계 구축	2	o 침해사고 조사를 위한 로그 수집·보관 및 증적 분석 도구·절차의 사전 준비 여부를 점검
71	o	o	비상 접근 절차 수립	2	o 비상 상황 시 클라우드 자원 접근을 위한 별도 절차 마련 및 문서화·테스트 여부를 점검
72	o	o	중요 데이터 백업 및 복구 정책 적용 여부	5	o 중요 전산자료 및 로그의 정기적 백업과 백업 파일의 무결성 검증 여부를 점검
73	o	o	관리용 단말기 보호대책 적용 여부	5	o 클라우드 관리용 단말기를 중요단말기로 지정하고 강화된 보호대책(인터넷 접속·매체 제어 등) 적용 여부를 점검

서버, 웹서버-WAS

❖ 평가대상

A	B	C	D	E	F	G	H	I	J
AIX 계열	HP-UX 계열	LINUX 계열	Solaris 계열	Windows 계열	Apache	WebtoB	IIS	Tomcat	JEUS

❖ 평가기준

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
1	o	o	o	o	o						안전한 네트워크 모니터링 서비스 사용	3	o 알맞은 버전 및 안전한 보안설정을 적용하여 사용하고 있는지 여부를 점검
2	o	o	o	o	o						네트워크 모니터링 서비스 접근통제 설정 적절성	3	o 네트워크 모니터링 서비스를 사용할 수 있는 호스트를 특정하여 접근통제를 수행하고 있는지 점검
3	o	o	o	o	o						불필요한 SMTP 서비스 비활성화	3	o 불필요한 SMTP 서비스가 가동되고 있는지 여부를 점검
4	o	o	o	o							SMTP 서비스의 expn/vrfy 명령어 실행 제한 여부	3	o SMTP서비스에서 제공하는 expn/vrfy 명령어 허용 여부를 점검
5	o	o	o	o							SMTP 서비스 로그 수준 설정 적절성	2	o SMTP 로그 수준이 적절하게 설정되어 있는지 점검
6	o	o	o	o							SMTP 서비스 보안 패치 적용 여부	5	o 취약한 SMTP 서비스 버전 사용 여부를 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
7	o	o	o	o							SMTP 서비스의 DoS 방지 기능 설정 여부	1	o 메일 서비스 거부 및 시스템 다운을 방지하기 위한 보안설정의 적정성을 점검
8	o	o	o	o							SMTP 서비스 스팸 메일 릴레이 제한 설정 여부	4	o SMTP relay 제한 설정 여부를 점검
9	o	o	o	o							SMTP 서비스의 메일 queue 처리 권한 설정 적절성	4	o SMTP 메일 queue 처리 설정의 적절성을 점검
10	o	o	o	o							시스템 관리자 계정의 FTP 사용 제한 여부	3	o 시스템 관리자 계정의 FTP 접속을 제한하고 있는지 점검
11	o	o	o	o							.netrc 파일 내 중요 정보 미포함 여부	4	o .netrc파일 존재 여부 점검
12	o	o	o	o	o						Anonymous 계정의 FTP 서비스 접속 제한 여부	5	o FTP 서비스의 익명(Anonymous) 계정 접근 허용 여부를 점검
13	o	o	o	o							NFS 접근통제 설정 적절성	5	o NFS 접근통제 설정이 적절한지 여부를 점검
14	o	o	o	o							불필요한 NFS 서비스 비활성화	4	o 불필요한 NFS서비스가 실행되고 있는지 여부를 점검
15	o	o	o	o							불필요한 RPC 서비스 비활성화	4	o 불필요한 RPC서비스가 활성화되고 있는지 여부를 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
16					o						불필요한 하드디스크 기본 공유 비활성화	4	o 불필요한 시스템 기본 공유가 활성화되어 있는지 여부를 점검
17					o						공유 기능에 대한 접근통제 설정 적절성	5	o 공유 기능에 대한 사용자 권한 및 사용자 그룹 등 보안 설정의 적절성을 점검
18	o	o	o	o	o						FTP 서비스 접근통제 설정 적절성	5	o FTP 서비스 접근 제어 설정의 적절성 여부를 점검
19	o	o	o	o	o						계정의 비밀번호 미설정, 빈 암호 사용 관리 여부	3	o 계정에 비밀번호가 설정되어 있지 않거나 빈 비밀번호를 설정하였는지를 점검
20					o						원격 터미널 서비스의 암호화 설정 적절성	3	o 원격 터미널 서비스의 암호화 설정의 적절성을 점검
21					o						취약한 Telnet 인증 방식 사용 제한 여부	3	o 취약한 Telnet 인증 방식 사용 여부를 점검
22	o	o	o	o							hosts.equiv 또는 .rhosts 설정 제한 여부	5	o 모든 사용자가 인증절차 없이 r 계열 명령어를 실행할 수 있는 등 보안 수준이 낮은 설정이 존재하는지 점검
23	o	o	o	o							root 계정 원격 접속 제한 여부	5	o root 계정의 직접적인 원격 접속을 차단하고 있는지 여부를 점검
24	o	o	o	o	o						서비스 접근 IP 및 포트 제한 여부	4	o 웹서비스에 대한 IP 및 포트 접근제어를 수행하고 있는지 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
25	o	o	o	o	o						원격 터미널 접속 타임아웃 설정 여부	2	o 세션 종료시간 설정 여부, 세션 종료시간이 과도하게 설정되어 있는지 점검
26					o						SMB 세션 중단 관리 설정 여부	3	o 유효한 로그인 시간이 초과된 SMB 세션이 자동으로 종료되도록 설정되었는지 점검
27					o						계정 목록 및 네트워크 공유 이름 노출 방지 여부	5	o SAM 계정과 공유의 익명 열거를 방지하고 있는지 점검
28	o	o	o	o	o						불필요한 서비스 비활성화	3	o 불필요한 서비스들이 설치되어 실행되고 있는지 점검
29	o	o	o	o							취약한 서비스 비활성화	5	o 취약한 서비스가 실행되고 있는지 점검
30	o	o	o	o	o						취약한 FTP 서비스 비활성화	3	o FTP서비스가 추가 보안 수단 없이 취약하게 실행되고 있는지 점검
31	o	o	o	o	o	o	o	o	o	o	웹 서비스 디렉터리 리스팅 방지 설정 여부	5	o 디렉터리 리스팅 기능의 활성화 여부를 점검
32					o				o		웹 서비스의 CGI 스크립트 관리 여부	5	o CGI 디렉터리의 권한이 적절하게 설정되어있는지 여부를 점검
33	o	o	o	o	o	o			o		웹 서비스 상위 디렉터리 접근 제한 설정 여부	5	o 상위 경로를 사용하지 못하도록 적절하게 설정하였는지 점검
34	o	o	o	o	o	o	o	o	o	o	웹 서비스 경로 내 불필요한 파일 관리 여부	4	o 웹 서비스 경로 내 불필요한 파일의 존재 여부를 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
35	o	o	o	o	o	o	o	o	o	o	웹 서비스 파일 업로드 및 다운로드 용량 제한 설정 여부	4	o 대량의 업로드와 다운로드에 대한 통제 여부를 점검
36	o	o	o	o	o	o	o	o	o		웹 서비스 프로세스 권한 제한 여부	5	o 웹 서비스 프로세스 권한이 적절하게 설정되어 있는지 여부를 점검
37	o	o	o	o	o	o	o	o	o	o	웹 서비스 경로 설정 적절성	4	o 웹 서비스 경로 설정의 적절성을 점검
38	o	o	o	o	o	o		o			웹 서비스 경로 내 불필요한 링크 파일 관리 여부	4	o 웹 서비스 경로 내 불필요한 링크 파일 존재 여부를 점검
39	o	o	o	o	o	o	o	o	o	o	불필요한 웹 서비스 비활성화	3	o 불필요한 웹 서비스가 활성화되어 있는지 여부를 점검
40					o			o			웹 서비스 설정 파일 노출 방지 여부	5	o 웹 서비스 설정 파일에 대한 접근통제의 적절성 여부 등을 점검
41					o			o			웹 서비스 경로 내 파일의 접근통제 설정 적절성	5	o 웹 서비스 경로 내 파일의 실행 및 읽기 방지가 이루어지고 있는지 점검
42					o			o			웹 서비스의 불필요한 스크립트 매핑 제거	4	o 업무와 관계없는 불필요한 스크립트가 매핑되어 있는지 여부를 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
43					o			o			웹 서비스 서버 명령 실행 기능 제한 설정 적절성	5	o 웹 서비스 서버 명령 실행 기능 제한 설정의 적절성 여부를 점검
44	o	o	o	o	o				o	o	웹 서비스 기본 계정(아이디 또는 비밀번호) 변경 여부	5	o 웹 서비스 기본 계정에 대한 보안 설정의 적절성 여부를 점검
45	o	o	o	o							DNS 서비스 정보 노출 방지 여부	1	o DNS 서비스 정보가 노출되지 않도록 적절한 보안 설정이 되었는지 점검
46	o	o	o	o	o						DNS Recursive Query 제한 설정 여부	3	o DNS 서버가 불필요하게 Recursive Query를 지원하고 있는지 점검
47	o	o	o	o							DNS 서비스 보안 패치 적용 여부	5	o 주기적인 DNS 보안 패치를 통해 안전한 서비스를 운영하고 있는지에 대한 점검
48	o	o	o	o	o						DNS Zone Transfer 제한 설정 적절성	4	o DNS Zone Transfer 기능 제한 설정의 적절성 여부를 점검
49	o	o	o	o	o						비밀번호 관리정책 설정 적절성	5	o 적절한 비밀번호 관리정책이 설정되어 있는지 여부를 점검
50	o	o	o	o	o						취약한 패스워드 저장 방식 사용 제한 여부	5	o 패스워드 저장 방식의 적절성 여부를 점검
51					o						기본 관리자 계정명(Administrator) 변경 여부	4	o Administrator 계정의 계정명 변경 유무를 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
52	o	o	o	o	o						관리자 그룹에 불필요한 사용자 제거	4	o 관리자 그룹에 업무상 필요한 최소한의 사용자만 등록하여 사용하고 있는지 여부를 점검
53	o	o	o	o	o						불필요하거나 관리되지 않는 계정 제거	4	o 불필요한 계정 삭제 및 내부 정책에 따른 주기적인 비밀번호 변경을 실시하고 있는지 여부를 점검
54	o	o	o	o	o						비밀번호 복잡도 설정	5	o 강력한 패스워드가 설정될 수 있도록 암호 복잡성을 설정하고 회사에서 정한 비밀번호 관리정책 준수 여부를 점검
55					o						불필요한 Guest 계정 비활성화	4	o Guest 계정을 비활성화하여 접근 권한이 없는 사용자의 접근을 제한하고 있는지를 점검
56					o						익명 사용자에게 부적절한 권한(Everyone) 제거	5	o 익명 사용자에게 부적절한 권한(Everyone) 제거 여부를 점검
57					o						일반 사용자의 프린터 드라이버 설치 제한 여부	3	o 일반 사용자의 프린터 드라이버 설치를 제한하고 있는지 여부를 점검
58	o	o	o	o							Crontab 설정파일 권한 설정 적절성	4	o Crontab 설정 파일에 부여된 권한의 적절성을 점검
59	o	o	o	o	o						시스템 주요 디렉터리 권한 설정 적절성	4	o 시스템 주요 디렉터리에 부여된 권한의 적절성을 점검
60	o	o	o	o							시스템 스타트업 스크립트 권한 설정 적절성	3	o 시스템 스타트업 스크립트 권한 설정의 적절성을 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
61	o	o	o	o	o						시스템 주요 파일 권한 설정 적절성	5	o 시스템 주요 파일 권한 설정의 적절성을 점검
62	o	o	o	o							설치된 C 컴파일러 권한 설정 적절성	3	o C 컴파일러 설치 여부 및 권한 부여의 적절성을 점검
63					o						불필요한 원격 레지스트리 서비스 비활성화	5	o 불필요한 원격 레지스트리 서비스의 활성화 여부를 점검
64	o	o	o	o							불필요하게 SUID, SGID bit가 설정된 파일 제거	4	o 불필요한 SUID, SGID가 설정된 파일이 존재하는지 점검
65	o	o	o	o	o						사용자 홈 디렉터리 경로 및 권한 설정 적절성	4	o 사용자별 홈 디렉터리 경로 및 접근 권한의 적절성을 점검
66	o	o	o	o							불필요한 world writable 파일 제거	4	o 불필요한 World Writable 파일 및 디렉터리 권한이 존재하는지 점검
67	o	o	o	o							Crontab 참조파일 권한 설정 적절성	4	o Crontab 참조파일 권한 설정의 적절성을 점검
68	o	o	o	o							존재하지 않는 소유자 및 그룹 권한을 가진 파일 또는 디렉터리 제거	4	o 불필요한 계정이 삭제된 이후 해당 계정이 생성한 디렉터리 및 파일 등이 서버에 남아있는지 점검
69	o	o	o	o							사용자 환경파일의 소유자 또는 권한 설정 적절성	4	o 사용자 환경파일의 소유자 또는 권한 설정 적절성을 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
70					o						FTP 서비스 디렉터리 접근권한 설정 적절성	4	o FTP 홈 디렉터리의 접근 권한 설정 적절성을 점검
71					o						불필요한 예약된 작업 제거	3	o 예약 작업 목록에 의심스러운 작업이 존재하는지 점검
72					o						LAN Manager 인증 수준 적절성	3	o 네트워크 로그온을 사용하는 경우 보다 안전한 인증을 위한 NTLMv2 사용 설정 여부를 점검
73					o						보안 채널 데이터 디지털 암호화 또는 서명 기능 설정 적절성	3	o 보안 채널 데이터 디지털 암호화 또는 서명 기능 설정 적절성 여부를 점검
74					o						불필요한 시작프로그램 제거	3	o 시작프로그램 목록을 수시로 검사하여 불필요하거나 의심스러운 프로그램이 존재하는지 점검
75	o	o	o	o	o						로그에 대한 접근통제 및 관리 적절성	3	o 로그에 대한 접근 권한의 적절성을 점검
76	o	o	o	o	o						시스템 주요 이벤트 로그 설정 적절성	3	o 인증 관련이나 중요 이벤트 로그가 남도록 설정되었는지 점검
77	o	o	o	o							Cron 서비스 로깅 설정 적절성	2	o Cron 서비스 실행에 대한 적절한 로깅 설정이 되어있는지 점검
78	o	o	o	o	o						로그의 정기적 검토 및 보고 수행 여부	4	o 정기적으로 로그에 대한 검토 및 보고가 이루어지고 있는지 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
79					o						“보안 감사를 수행할 수 없는 경우, 즉시 시스템 종료” 기능 비활성화	5	o “보안 감사를 수행할 수 없는 경우, 즉시 시스템 종료” 기능 비활성화 여부를 점검
80	o	o	o	o	o	o	o	o	o	o	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	o 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행 (또는 보호방안 수립) 여부를 점검
81					o						백신 프로그램 업데이트 적용 여부	5	o 백신 프로그램에 악성코드 정보에 대한 주기적인 업데이트가 적절하게 이루어지고 있는지 점검
82	o	o	o	o							root 계정의 PATH 환경변수 설정 적절성	5	o 관리자의 PATH 환경변수에 현재 디렉터리 또는 알 수 없는 디렉터리가 포함되지 않았는지 점검
83	o	o	o	o							umask 설정 적절성	3	o 적절한 umask 값이 설정되었는지 점검
84					o						최종 로그인 사용자 계정 노출 방지 여부	3	o 최종 로그인 사용자 계정 노출 설정의 적절성을 점검
85					o						화면보호기 설정 적절성	4	o 적절하게 화면보호기를 설정하였는지 점검
86					o						자동 로그온 방지 설정 여부	4	o 불필요한 자동 로그온 설정이 존재하는지 점검
87	o	o	o	o	o						로그인 실패 횟수에 따른 접속 제한 설정	4	o 로그인 입력 횟수 제한 등의 임계값 설정 여부를 점검
88					o						NTFS 파일 시스템 사용 여부	3	o 보다 강화된 보안 기능을 지원하는 NTFS 파일시스템 사용 여부를 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
89					o						백신 프로그램 설치 여부	5	o 악성코드 감염 대비 및 치료 수행을 위한 백신 프로그램의 설치 여부를 점검
90	o	o	o	o							SU 명령 사용가능 그룹 제한 설정 적절성	3	o su 명령을 사용할 수 있는 그룹을 설정하여 해당 그룹에 속한 사용자에게만 명령을 허용하고 있는지 여부를 점검
91	o	o	o	o							Cron 서비스 사용 계정 제한 설정 적절성	3	o Cron 서비스 사용 계정에 대한 접근 통제를 수행하고 있는지 점검
92				o							스택 영역 실행 방지 설정 여부	2	o 스택 영역 실행 기능에 대한 보안설정의 적절성을 점검
93				o	o						TCP 보안 설정 여부	2	o TCP 연결의 보안을 강화하는 설정이 활성화 되어 있는지 점검
94					o						로그온 단계에서 "시스템 종료" 기능 비활성화	5	o 로그온 단계에서의 시스템 종료 기능 비활성화 여부를 점검
95					o						네트워크 서비스 접근 권한 적절성	3	o 네트워크 서비스 접근 권한 적절성을 점검
96					o						백업 및 복구 권한 설정 적절성	2	o 불필요한 사용자 및 그룹에게 부여된 백업 및 복구 권한이 존재하는지 점검
97					o						시스템 자원 소유권 변경 권한 설정 적절성	3	o 시스템 자원 소유권 변경 권한 설정의 적절성을 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
98					o						이동식 미디어 포맷 및 꺼내기 허용 정책 설정 적절성	4	o 이동식 미디어(USB 등) 포맷 및 꺼내기 허용 권한 설정의 적절성을 점검
99	o	o	o	o							중복 UID가 부여된 계정 제한 여부	4	o 동일한 UID가 부여된 계정의 존재 여부를 점검
100	o	o	o	o							/dev 경로에 불필요한 파일 제거	4	o 실제 존재하지 않는 디바이스 파일이 /dev 경로에 있는지 점검
101	o	o	o	o	o						불필요한 네트워크 모니터링 서비스 비활성화	3	o 불필요한 네트워크 모니터링 서비스가 구동 중인지에 대한 점검
102	o	o	o	o	o	o	o	o	o	o	웹 서비스 정보 노출 방지 여부	3	o 웹 서비스 정보 노출 방지를 위한 적절한 보안 설정이 되었는지 점검
103					o						디스크 볼륨 암호화 적용 여부	4	o 디스크 볼륨 암호화 적용 여부를 점검
104					o						로컬 로그인 허용 계정 제한 여부	3	o 로컬 로그인이 허용된 계정이 존재하는지 점검
105					o						익명 SID/이름 변환 설정 제한 여부	3	o 익명 SID/이름 변환 설정 활성화 여부를 점검
106					o						원격터미널 접속 가능한 사용자 그룹 제한 여부	3	o 원격터미널 접속 가능한 사용자 그룹 제한 설정을 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
107	o	o	o	o	o						불필요한 Telnet 서비스 비활성화	3	o Telnet 서비스가 불필요하게 활성화되어 있는지 점검
108	o	o	o	o							ftpusers 파일의 소유자 및 권한 설정 적절성	3	o ftpusers 파일에 대한 권한 설정의 적절성을 점검
109	o	o	o	o	o						시스템 사용 주의사항 출력	1	o 로그인 시 경고 및 시스템 사용 주의사항 등의 문구를 표시하고 있는지 점검
110	o	o	o	o							구성원이 존재하지 않는 GID 제거	2	o 소속된 계정이 없는 GID가 존재하는지 점검
111	o	o	o	o							불필요하게 Shell이 부여된 계정 제거	1	o 불필요하게 Shell이 부여된 계정 존재 여부를 점검
112	o	o	o	o	o						불필요한 숨김 파일 또는 디렉터리 제거	1	o 숨김 파일 및 디렉터리 중 침해 행위로 인해 생성된 파일이 존재하는지 점검
113	o	o	o	o	o						SMTP 서비스 정보 노출 방지 여부	1	o 불필요하게 노출되는 SMTP 서비스 정보 유무를 점검
114	o	o	o	o	o						FTP 서비스 정보 노출 방지 여부	1	o 불필요하게 노출되는 FTP 서비스 정보 존재 유무를 점검
115					o						불필요한 시스템 자원 공유 제거	3	o 불필요한 자원 공유의 존재 여부를 점검
116	o	o	o	o	o						DNS 서비스 동적 업데이트 설정 적절성	3	o DNS 서비스 동적 업데이트 설정 적절성을 점검

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
117	o	o	o	o	o						불필요한 DNS 서비스 비활성화	3	o DNS 서비스가 업무와 관계없이 활성화되어 있는지 여부를 점검
118	o	o	o	o	o						시간 동기화를 위한 NTP 설정	2	o NTP 설정 여부를 점검
119	o	o	o	o							sudo 명령어 접근 권한 설정 적절성	3	o sudo 명령어 접근 권한이 적절하게 관리되고 있는지 점검
120					o						개인 키 사용 시 passphrase 설정 여부	4	o 키 파일의 passphrase 설정 여부를 점검
121	o	o	o	o	o	o	o	o			웹 서비스 불필요한 프록시 설정 제한 여부	4	o 웹 서비스의 불필요한 Proxy 설정을 제한하는지 여부를 점검
122	o	o	o	o	o	o		o	o		웹 서비스 불필요한 SSI(Server Side Includes) 기능 비활성화	3	o 웹 서비스 불필요한 SSI(Server Side Includes) 기능 비활성화 여부를 점검
123	o	o	o	o	o	o	o	o	o	o	웹 서비스 기본 에러 페이지 노출 방지 여부	2	o 웹 서비스의 에러 페이지를 설정하였는지 여부를 점검
124	o	o	o	o	o	o		o	o	o	웹 서비스 부적절한 LDAP 알고리즘 설정 제한 여부	3	o LDAP 연결 중 취약/구식 알고리즘을 이용한 설정이 존재 하는지 점검
125	o	o	o	o	o	o	o	o	o	o	웹 서비스 독립된 업로드 경로 및 권한 설정 여부	3	o 웹 서비스의 독립된 업로드 경로 사용 및 권한 설정을 확인

ID	A	B	C	D	E	F	G	H	I	J	평가항목	위험도	상세설명
126	○	○	○	○	○	○	○	○	○	○	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	4	○ 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검

데이터베이스

❖ 평가대상

A	B	C	D	E	F
ORACLE	MSSQL	MYSQL	PostgreSQL	MariaDB	Tibero

❖ 평가기준

ID	클라우드	A	B	C	D	E	F	평가항목	위험도	상세설명
1	o	o	o	o	o	o	o	취약하게 설정된 비밀번호 제거	4	o 취약하게 설정된 비밀번호가 있는지 점검
2	o	o	o	o	o	o	o	불필요하거나 관리되지 않는 계정 제거	4	o 불필요한 계정이 존재하는지 점검
3	o	o	o	o	o	o	o	불필요한 관리자 계정 제거	5	o 불필요하게 관리자 권한이 부여된 계정이 존재하는지 점검
4	o	o	o	o	o	o	o	데이터베이스 내 중요정보 안전한 암호화 적용 여부	5	o 중요 정보를 안전한 암호화 알고리즘을 사용하여 보관하고 있는지 점검
5	o	o	o	o	o	o	o	로그인 실패 횟수에 따른 접속 제한 설정	3	o 로그인 실패 횟수에 따라 일시 또는 영구적으로 접속을 제한하고 있는지 점검

ID	클라우드	A	B	C	D	E	F	평가항목	위험도	상세설명
6	o	o	o	o	o	o	o	비밀번호 복잡도 설정	5	o 비밀번호 설정 시 복잡도 정책이 적절하게 설정되어 있는지 점검
7	o	o	o	o	o	o	o	비밀번호 변경 주기 충족 여부	4	o 내부 정책에 따라 주기적으로 비밀번호 변경을 실시하고 있는지 점검
8	o	o	o	o	o	o	o	사용되지 않는 세션 종료 여부	3	o 자동 세션종료 설정을 통해 사용되지 않는 세션 종료 여부를 점검
9	o	o	o	o	o	o	o	감사 로그 수집 및 백업 여부	5	o 로그 수집 및 백업이 적절하게 이루어지고 있는지 점검
10		o						Listener Control Utility(Isnrnctl) 보안 설정 여부	5	o Listener Control Utility(Isnrnctl)의 보안 설정 여부를 점검
11	o	o	o	o	o	o	o	원격 접속에 대한 접근 제어 여부	5	o 원격 접속에 대한 통제 여부를 점검
12	o	o						취약한 운영체제 역할 인증 기능(OS_ROLES, REMOTE_OS_ROLES) 비활성화	4	o 운영체제 역할 인증 기능(OS_ROLES, REMOTE_OS_ROLES) 활성화 여부를 점검
13	o	o	o		o		o	Public Role에 불필요한 권한 제거	4	o 불필요한 권한이 Public Role에 부여되어있는지 점검

ID	클라우드	A	B	C	D	E	F	평가항목	위험도	상세설명
14	o	o	o	o	o	o	o	최신 보안패치와 벤더 권고사항 적용 여부	4	o 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행(또는 보호방안 수립) 여부를 점검
15	o	o	o	o	o	o	o	업무상 불필요한 시스템 테이블 접근 권한 제거	5	o 인가되지 않은 사용자에게 시스템 테이블 접근 권한이 부여되어 있는지 점검
16	o	o	o	o	o	o	o	이전 비밀번호 재사용 요구사항 충족 여부	3	o 이전에 사용된 비밀번호의 재사용 방지 설정 여부를 점검
17	o	o	o	o	o	o	o	사용자별 계정 분리	3	o 계정을 사용자별로 분리하여 사용하고 있는지 점검
18			o					업무상 불필요한 ODBC/OLE-DB 데이터 소스 및 드라이버 제거	3	o 불필요한 ODBC, OLE-DB 데이터 소스 및 드라이버를 제거하였는지 점검
19		o	o	o	o	o	o	설정 파일 및 중요정보가 포함된 파일의 접근 권한 설정 적절성	3	o 주요 설정 파일 및 중요정보 파일들의 접근권한이 적절한지 점검
20	o	o	o	o	o	o	o	불필요하게 WITH GRANT OPTION 옵션이 설정된 권한 제거	3	o 불필요하게 WITH GRANT OPTION 옵션이 설정되어 있는 권한이 있는지 점검
21	o	o	o	o	o	o	o	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	4	o 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검

ID	클라우드	A	B	C	D	E	F	평가항목	위험도	상세설명
22		o		o	o	o	o	데이터베이스 구동 계정의 umask 설정 미흡	2	o 데이터베이스 구동 계정의 umask 설정 적절성 여부를 점검
23	o	o	o	o	o	o	o	업무상 불필요한 데이터베이스 Object 제거	1	o 업무상 불필요한 데이터베이스 Object가 존재하는지 점검
24	o	o						데이터베이스의 자원 사용 제한 설정 미흡	1	o 자원 사용 제한 설정의 활성화 여부를 점검
25	o	o					o	Audit Table에 대한 접근 제어 미흡	1	o Audit Table의 수정/삭제 권한을 관리자 계정으로 제한하는지 점검
26			o					SA 계정에 대한 보안설정 미흡	3	o SA계정이 활성화 되어있는 경우 적절한 보안 정책이 적용되고 있는지 점검
27	o				o			데이터베이스 접속 시 통신구간에 비밀번호 평문 노출	3	o 데이터베이스 접속시 비밀번호가 평문으로 노출되는지 점검
28				o				DB 이중화 구성 시 비밀번호 평문 노출	4	o 데이터베이스의 이중화 설정의 적정성을 점검
29		o		o	o	o	o	DBMS 서비스 구동 권한 적절성	3	o DBMS 서비스 구동 권한이 적절하게 설정되어 있는지 점검
30	o		o					xp_cmdshell 사용 비활성화	5	o xp_cmdshell 사용이 제한되어 있는지 점검

ID	클라우드	A	B	C	D	E	F	평가항목	위험도	상세설명
31	o		o					Registry Procedure 접근 권한 설정 적절성	5	o Registry Procedure 접근 권한 제한 여부를 확인

네트워크 인프라

❖ 평가기준

ID	평가항목	위험도	상세설명
1	네트워크 회선(ISP) 이중화 구성	3	○ 네트워크 회선(ISP)을 이중화하여 구성하고 있는지 점검
2	네트워크 장비 이중화 구성	3	○ 네트워크 장비를 이중화 구성하고 있는지 점검
3	정보보호시스템 이중화 구성	3	○ 정보보호시스템을 이중화 구성하고 있는지 점검
4	중요 서버 이중화 구성	3	○ 중요서버를 이중화 구성하고 있는지 점검
5	재해 또는 장애발생 시 복구를 위한 별도 구간 확보 여부	3	○ 재해복구센터 또는 백업센터 등의 네트워크 구간 마련 여부를 점검
6	업무 특성별 네트워크 망분리 구성	5	○ 네트워크 구간을 업무 특성별로 적절하게 분리하고 있는지 점검
7	개발/테스트와 운영 네트워크 망분리 구성	5	○ 개발/테스트와 운영 네트워크 구간을 별도로 분리하여 운영하고 있는지 점검
8	사용자들의 주요 서버구간으로의 접근통제	4	○ 사용자 단말에서 주요 서버 접근 시 해당 사용자의 권한에 맞는 접속만 허용되도록 통제를 수행하고 있는지 점검
9	분리된 각 네트워크 구간 사이에 접근통제	4	○ 분리된 네트워크 구간 사이에 적절한 접근통제를 수행하고 있는지 점검
10	보안 정책 미적용 우회 경로 유무 여부	4	○ 네트워크 접점의 우회경로가 있는지 점검

ID	평가항목	위험도	상세설명
11	외부통신망에서 접근이 불필요한 구간에 대한 접근통제 여부	5	○ 외부로부터 직접 접근이 가능한 구간 또는 시스템이 있는지 점검
12	내부통신망 공인IP 사용 통제	3	○ 내부통신망에 불필요하게 공인IP가 할당되어 있는지 점검
13	내부구간에 위치한 정보시스템(서버,DB)에 대한 외부통신망 차단 여부	5	○ 내부구간 정보시스템에서 외부로의 접근 허용 여부 점검
14	중요 단말기에서 외부통신망 및 내부통신망(그룹웨어 등)에 대한 접근통제의 적절성	5	○ 중요 단말기에서 외부통신망 및 내부통신망(그룹웨어 등)에 접근통제 여부 점검
15	장애 인지 및 대응 방안 수립 여부	1	○ 모니터링 시스템을 통해 장애 발생에 대한 즉각적인 인지 및 대응 방안이 마련되어 있는지 점검
16	네트워크 구간별 침입탐지시스템 구성의 적절성	4	○ 네트워크 구간 중 탐지예외 구간이 있는지 점검
17	외부통신망과 통신을 하는 서버(웹 서버 등)의 DMZ 구성의 적절성	3	○ 공개용 서버가 내부구간에 존재하는 지 여부 점검
18	네트워크 관리시스템의 작업내역, 로그관리 및 사용자권한 설정에 대한 보안설정의 적절성	3	○ 네트워크 관리시스템의 작업내역, 로그관리 및 사용자권한 설정에 대한 보안설정의 적절성을 점검

네트워크 장비

❖ 평가대상

A	B	C	D
CISCO 계열	A10 계열	BROCADE, ALTEON, NOTEL, BIGIP, CITRIX, PIOLINK 계열	3COM, JUNIPER 계열

❖ 평가기준

ID	스위치	라우터	A	B	C	D	평가항목	위험도	상세설명
1	o	o	o	o	o	o	네트워크 장비 설정 백업 여부	4	o 네트워크 장비 설정 백업 여부를 점검
2	o	o	o	o	o	o	안전한 네트워크 모니터링 서비스 사용 여부	4	o 알맞은 네트워크 모니터링 서비스 보안설정 및 안전한 버전을 적용하여 사용하고 있는지 여부를 점검
3	o	o	o	o	o	o	SNMP 커뮤니티 권한 설정 적정성	4	o 네트워크 설정 정보를 변경할 수 없도록 SNMP 커뮤니티 권한 설정 적정성을 점검
4	o	o	o	o	o	o	SNMP 접근통제(ACL) 설정 여부	5	o 네트워크 정보 노출을 제한하기 위해 SNMP 접근통제(ACL) 설정 여부를 점검
5		o	o		o		외부인터페이스 SNMP 접근 차단 여부	1	o 비인가자의 접근을 제한하기 위해 외부인터페이스의 SNMP 접근 차단 여부를 점검
6	o	o	o	o	o	o	Local 사용자 생성 및 권한관리 여부	3	o 비인가자의 접근을 차단을 위해 Local 사용자 생성 여부 및 권한관리 여부를 점검

ID	스위치	라우터	A	B	C	D	평가항목	위험도	상세설명
7	o	o	o	o	o	o	강화된 인증기능(AAA) 사용 여부	3	o 인증 기능을 활성화하여 비인가자의 접근을 차단 강화된 인증기능(AAA) 사용 여부를 점검
8	o	o	o	o	o	o	중복 비밀번호 및 비밀번호 미설정 금지 여부	5	o 중복 비밀번호 및 비밀번호 미설정 금지 여부를 점검
9	o	o	o	o	o		enable secret 설정 여부	5	o 비인가자가 쉽게 Enable 비밀번호를 식별할 수 없도록 enable secret 설정 여부를 점검
10	o	o	o	o	o	o	안전한 암호화 알고리즘 설정 여부	5	o 비인가자의 장비 내 비밀번호 식별을 어렵게 하기 위해 안전한 암호화 알고리즘 설정 여부를 점검
11	o	o	o	o	o	o	비밀번호 복잡도 정책 준수 여부	5	o 공격자가 네트워크 장비에 접속 시도 시 접근이 용이하지 않게 하기 위해 비밀번호 복잡도 정책 준수 여부를 점검
12	o	o	o	o	o	o	원격 관리 접근 통제 여부	5	o 허가된 사용자 외에 비인가자의 접근을 차단하기 위해 원격 관리 접근 통제 여부를 점검
13	o	o	o	o	o	o	세션 타임아웃 설정 여부	4	o 세션에 대한 자동 종료시간 설정 여부 및 과도한 세션 시간 설정 여부를 점검
14	o	o	o	o	o	o	VTY 접속 시 안전하지 않은 프로토콜(TELNET 등) 사용 제한 여부	4	o 평문데이터가 공격자에게 노출되지 않게 하기 위해 VTY 접속 시 안전하지 않은 프로토콜(TELNET 등) 사용 제한 여부를 점검
15	o	o	o				불필요한 보조 입출력 포트(AUX) 차단 여부	2	o 비인가자의 접근을 차단하기 위해 불필요한 보조 입출력 포트(AUX) 차단 여부를 점검

ID	스위치	라우터	A	B	C	D	평가항목	위험도	상세설명
16		o	o	o			불필요한 Source 라우팅 차단 설정 여부	2	o 비인가자에 의해 공격에 악용되는 것을 차단하기 위해 불필요한 Source 라우팅 차단 설정 여부를 점검
17		o	o			o	Proxy ARP 차단 설정 여부	3	o 라우터와 네트워크 관련 정보를 획득을 차단하기 위해 Proxy ARP 차단 설정 여부를 점검
18	o	o	o	o			IP Directed Broadcast 차단 설정 여부	3	o DoS 공격(Smurf 공격 등)을 차단하기 위해 IP Directed Broadcast 차단 설정 여부를 점검
19	o	o	o	o	o	o	불필요한 서비스 비활성화 여부	2	o 불필요한 서비스 활성화 여부를 점검
20	o	o	o	o	o	o	NTP 설정 및 시각 동기화 여부	3	o NTP 설정 및 시각 동기화 여부를 점검
21	o	o	o	o	o	o	로깅 활성화 설정 여부	3	o 네트워크 장비 운영 및 보안 모니터링을 위해 로깅 활성화 설정 여부를 점검
22	o	o	o	o		o	로깅 메시지 시간 설정 여부	1	o 공격에 대한 분석이 가능하도록 로깅 메시지 시간 설정 여부를 점검
23	o	o	o	o	o	o	로깅 버퍼 사이즈 설정 여부	2	o 디버깅이나 모니터링 시에 활용하기 위해 로깅 버퍼 사이즈 설정 여부를 점검
24	o	o	o	o	o	o	원격 로그서버 연동 설정 여부	3	o 로그가 삭제될 수 있으므로 원격 로그서버 연동 설정 여부를 점검
25	o	o	o	o			콘솔 로깅 레벨 설정 적정성	1	o 불필요한 로그 메시지 출력을 방지하기 위해 콘솔 로깅 레벨 설정 적정성을 점검
26		o	o				외부 인터페이스에 ingress 필터 설정 여부	5	o 내부 네트워크로 유입되는 패킷을 필터링하기 위해 외부 인터페이스에 ingress 필터 설정 여부를 점검

ID	스위치	라우터	A	B	C	D	평가항목	위험도	상세설명
27		o	o				외부 인터페이스에 egress 필터 설정 여부	3	o 내부에서 외부로 전송되는 패킷을 필터링하기 위해 외부 인터페이스에 egress 필터 설정 여부를 점검
28		o	o				스푸핑방지 필터 설정 여부	4	o 스푸핑 공격을 차단하기 위해 스푸핑방지 필터 설정 여부를 점검
29		o	o				IP 멀티캐스트 차단 설정 여부	1	o 멀티캐스트 패킷을 필터 하여 공격에 악용되는 것을 차단하기 위해 IP 멀티캐스트 차단 설정 여부를 점검
30		o	o				ICMP 차단 설정 여부	2	o 서비스 거부공격 등을 차단하기 위해 ICMP 차단 설정 여부를 점검
31		o	o				ICMP redirect 차단 설정 여부	2	o 라우팅 테이블이 변경되는 것을 방지하기 위해 ICMP redirect 차단 설정 여부를 점검
32		o	o				ICMP unreachable 차단 설정 여부	2	o 네트워크 장비의 특정 포트 활성화 여부 노출 및 DoS 공격에 악용되는 것을 차단하기 위해 ICMP unreachable 차단 설정 여부를 점검
33		o	o				ICMP mask-reply 차단 설정 여부	2	o 비인가자에게 네트워크 구성정보가 노출되는 것을 차단 하기 위해 ICMP mask-reply 차단 설정 여부를 점검
34		o	o				ICMP Timestamp, Information Requests 차단 설정 여부	1	o 비인가자에게 네트워크 정보가 노출되지 않게 하기 위해 ICMP Timestamp, Information Requests 차단 설정 여부를 점검
35		o	o				서비스 거부(DDoS) 공격 차단 필터링 설정 여부	4	o 서비스 거부(DDoS) 공격 차단 필터링 설정 여부를 점검

ID	스위치	라우터	A	B	C	D	평가항목	위험도	상세설명
36	o	o	o	o	o	o	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	o 최신/긴급 패치에 대한 검토, 계획 수립, 계획에 따른 이행(또는 보호방안 수립) 여부를 점검
37	o	o	o	o			명령어 실행 권한 제한 여부	3	o 비인가자의 접근을 차단하기 위해 명령어 실행 권한 제한 여부를 점검
38	o	o	o	o	o	o	로그온 시 경고메시지 설정 여부	3	o 로그온 시 경고메시지 설정 여부를 점검
39		o	o				tcp keepalives 사용 설정 여부	3	o 하이재킹을 통한 공격 차단 및 세션의 정상적인 종료를 위해 tcp keepalives 사용 설정 여부를 점검
40	o	o	o	o	o	o	미사용 인터페이스 비활성화 설정 여부	4	o 미사용 인터페이스 비활성화 설정 여부를 점검
41	o		o	o	o	o	스위치 허브 보안 설정 여부	1	o 네트워크 트래픽이 비인가자에게 노출 또는 변조되는 것을 차단하기 위해 스위치 허브 보안 설정 여부를 점검
42	o	o	o	o	o	o	비밀번호의 주기적인 변경관리 여부	3	o 보안장비의 비밀번호를 주기적으로 변경/관리하는지 여부를 점검
43	o	o	o				취약한 서비스 비활성화 여부	2	o 취약한 서비스 구동 여부를 점검
44	o	o	o	o	o	o	계정 잠금 임계값 설정 여부 및 적정성	4	o 로그인 입력 횟수 제한 등의 임계값 설정 여부를 점검
45	o	o	o	o	o	o	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	5	o 서비스 지원이 종료된(EoS) 버전의 시스템 또는 장비 사용 여부를 점검

정보보호시스템 장비

❖ 평가대상

A	B	C	D	E	F
침입차단시스템 (FW)	가상사설망 (VPN)	침입탐지시스템 (IDS)	침입방지시스템 (IPS)	DDoS대응장비 (DDoS)	웹방화벽 (WAF)

❖ 평가기준

ID	A	B	C	D	E	F	평가항목	위험도	상세설명
1	o	o	o	o	o	o	보안장비 정책 및 로그 백업 설정 여부	4	- 보안장비 비상상황 발생시 신속한 복구를 위해 보안장비 정책 및 로그 백업 설정 여부를 점검
2	o	o	o	o	o	o	원격 로그 서버 사용 여부	3	- 로그파일이 삭제될 수 있으므로 원격에 별도 로그서버 설치 및 로그파일 을 관리하는지 여부를 점검
3	o	o					DMZ 구간 설정 여부	4	- 비인가자가 공개용 서버 구간의 호스트를 통해 내부 네트워크에 접근하는 것을 차단하기 위해 DMZ 구간 설정여부를 점검
4	o	o					NAT 정책 설정 적정성	4	- 시스템의 불필요한 네트워크 연결 경로가 구성되어있는지 확인 하기 위해 NAT 정책 설정 적정성을 점검
5	o	o	o	o	o	o	주기적인 보안패치 및 벤더 권고사항 적용 여부	5	- 시스템 패치에 대한 검토, 계획수립, 이행여부를 점검

ID	A	B	C	D	E	F	평가항목	위험도	상세설명
6	○	○	○	○	○	○	보안장비 사용량의 주기적인 점검 및 보고 여부	4	- 보안장비의 사용량을 검토하여, 장비 가용성을 확보하기 위해 사용량의 주기적 점검 및 보고 여부를 점검
7	○	○	○	○	○	○	보안장비 장애/보안이벤트 모니터링 실시 여부	4	- 보안장비 장애/이벤트 모니터링을 통해 실시간 대응을 하기 위해 이벤트 모니터링 실시 여부를 점검
8			○	○	○	○	탐지된 이벤트 및 로그에 대한 정기적 분석 및 보고 여부	3	- 이벤트 및 로그 분석을 통해 침해사고 발생 여부를 점검하기 위해 정기적 분석 및 보고 여부를 점검
9			○	○	○	○	위험도가 높은 이벤트 및 로그에 대한 RAW 패킷 저장 여부	2	- 사고 분석에 필요한 패킷 RAW 데이터 저장 여부를 점검
10			○	○	○		TCP/UDP/ICMP 탐지/차단 패턴 적용 여부	2	- 외부에서 인터넷망을 통한 공격시 내부 시스템을 보호하기 위해 패턴 적용 여부를 점검
11			○	○	○		Port Scan 탐지/차단 패턴 적용 여부	2	- 내부시스템의 접근 정보 획득을 차단하기 위해 패턴 적용 여부를 점검
12			○	○		○	해킹 툴 탐지/차단 패턴 적용 여부	2	- 악성코드의 내부 감염을 차단하기 위해 패턴 적용 여부를 점검
13	○	○					불필요한 Source Routing 차단 설정 여부	2	- 특정 경로를 통한 공격을 차단하기 위해 차단 설정 여부를 점검
14	○	○	○	○	○	○	사용하지 않는 SNMP 비활성화 여부	4	- SNMP서비스 취약점을 이용한 공격을 차단하기 위해 비활성화 여부를 점검

ID	A	B	C	D	E	F	평가항목	위험도	상세설명
15	o	o	o	o	o	o	안전한 네트워크 모니터링 서비스 사용 여부	4	- 보안설정 미비시 시스템 정보 등이 유출될 가능성이 존재하므로 안전한 보안설정 및 버전 적용 여부를 점검
16	o	o	o	o	o	o	보안장비 접속 시 보안 접속 사용 여부	5	- 비인가자에 의한 스니핑 공격에 노출을 방지하기 위해 보안 접속 사용 여부를 점검
17	o	o	o	o	o	o	보안장비 Default 계정 변경 여부	4	- 비인가자가 보안장비의 Default 계정을 통한 보안장비 접근을 차단하기 위해 계정 변경 여부를 점검
18	o	o	o	o	o	o	보안장비 Default 비밀번호 변경 여부	4	- 비인가자가 보안장비의 Default 비밀번호를 통한 보안장비 접근을 차단하기 위해 비밀번호 변경여부를 점검
19	o	o	o	o	o	o	보안장비 계정 관리 적정성	5	- 침해사고 발생시 계정의 권한, 감사증적 기록을 남기기 위해 계정 관리 적정성 여부를 점검
20	o	o	o	o	o	o	보안장비 계정별 권한 설정 여부	4	- 권한 없는 사용자에게 의한 권한 설정 변경을 방지하기 위해 권한 설정을 점검
21	o	o	o	o	o	o	보안장비 원격 관리 접근 통제 여부	5	- 허용된 IP만 보안장비만 접속 허용하여 비인가자 접근을 차단하기 위해 접근 통제 여부를 점검
22	o	o	o	o	o	o	보안장비 접속성공/실패 로깅 여부	3	- 비인가자의 접근을 확인하기 위해 로깅 여부를 점검
23	o	o	o	o	o	o	로그인 실패횟수 제한 설정 여부	3	- 반복적인 계정 및 비밀번호 입력을 통한 탈취를 방지하기 위해 실패횟수 제한 설정을 점검

ID	A	B	C	D	E	F	평가항목	위험도	상세설명
24	o	o	o	o	o	o	세션 타임아웃 설정 여부	4	- 사용자 부재시, 비인가자에 의한 시스템 무단 사용을 방지하기 위해 세션 타임아웃 설정을 점검
25	o	o	o	o	o	o	시간 동기화를 위한 NTP 설정	2	- 시스템 시각 정확성 및 이벤트 발생 시 정확한 로그 분석을 하기 위해 NTP 설정을 점검
26	o	o	o	o	o	o	주요 파일에 대한 주기적인 무결성 검사 여부	2	- 주요 파일의 불법 변조 여부를 확인하기 위해 주기적인 무결성 검사여부를 점검
27	o	o	o	o	o	o	보안장비 기능외 서비스 제한 여부	2	- 비인가자에 의해 공격에 활용되는것을 차단하기 위해 기능외 서비스 제한 여부를 점검
28	o	o					보안장비 정책 변경통제 절차 수립 여부	4	- 보안장비 정책을 임의적으로 생성, 변경 등을 차단하기 위해 절차 수립 여부를 점검
29	o	o					보안장비 변경요청 정책의 기술적 검토 여부	4	- 보안정책 신청에 대해 관리자가 적정성 여부를 검토후 적용하는지 확인
30	o	o					모든 목적지 및 서비스로의 허용 정책 금지 여부	5	- 허용정책으로 인해 비인가자에 의한 불필요한 접근할 수 있으므로, 이를 차단하기 위해 정책금지 여부를 점검
31	o	o					취약한 서비스의 네트워크 대역 단위 허용 금지 여부	5	- 네트워크 대역 단위 허용에 의해 비인가자에 의한 불필요한 접근 등이 발생할 수 있으므로, 이를 방지하기 위해 허용 금지여부를 점검

ID	A	B	C	D	E	F	평가항목	위험도	상세설명
32	o	o					서비스 포트 허용 정책 적정성	5	- 과도한 서비스 포트 허용에 따라 비인가자에 의한 불필요한 접근이 발생할 수 있으므로, 이를 차단하기 위해 포트 허용정책의 적정성을 점검
33	o	o					불필요한 양방향 정책 금지 여부	4	- 불필요한 정책설정에 따라 비인가자에 의한 불필요한 접근이 발생 할 수 있으므로, 이를 방지하기 위해 정책 금지 여부를 점검
34	o	o					정책 적용 순서의 적절성	4	- 잘못된 정책 적용으로 인해 비인가자에 의한 불필요한 접근을 허용할 수 있으므로 이를 차단하기 위해 정책 순서의 적절성을 점검
35	o	o					출발지 포트 기반의 정책 금지 여부	5	- 공격자가 출발지 포트를 속여 목적지 포트에 접근하는것을 차단 하기 위해 정책 금지 여부를 점검
36	o	o					취약한 원격 서비스 금지 여부	5	- 보안 취약점에 노출된 원격 서비스를 허용하고 있는지 점검하기 위해 원격 서비스 금지 여부를 점검
37	o	o					불필요한 정책 제거 여부	4	- 불필요한 정책을 제거 여부를 점검
38	o	o					서버간 관리포트 허용 금지 여부	5	- 서버간 관리포트 허용 등 취약한 정책 존재여부를 점검
39	o	o					단말과 서버간 접근통제를 우회한 접속 금지 여부	5	- 사용자 단말과 서버간 취약한 정책이 존재하는지 점검
40	o	o	o	o	o	o	보안장비 비밀번호의 주기적인 변경 여부	3	- 보안장비 비밀번호를 주기적으로 관리하는 여부를 점검

ID	A	B	C	D	E	F	평가항목	위험도	상세설명
41	o	o					불필요한 네트워크 대역 단위 설정 금지 여부	4	- 잘못된 대역 설정에 따른 비인가자의 불필요한 접근이 발생 할 수 있으므로, 이를 방지하기 위해 대역 단위 설정 금지 여부를 점검
42						o	차단 기능 활성화 여부	5	- 보안장비의 차단 기능 비활성화시 악의적인 공격에 노출될 수 있으므로, 차단 기능 활성화를 여부를 점검
43	o	o	o	o	o	o	서비스 지원이 종료된(EoS) 시스템 및 장비 교체 여부	5	- EoS버전 사용시 보안위협에 대처할 수 없으므로, EoS 버전의 시스템 또는 장비 사용여부를 점검

OS 가상화 시스템

❖ 평가대상

A	B	C
vCenter	ESXi	XenServer

❖ 평가기준

ID	A	B	C	평가항목	위험도	상세설명
1	o	o	o	사용자별 계정 분리	3	- 공용계정 사용시 감사추적이 어려움에 따라 공용 계정 사용여부를 점검
2	o	o	o	관리자 그룹 내 불필요한 계정 제거	5	- 필요한 최소한의 사용자만 관리자 그룹에 등록 및 사용하는지 여부 점검
3	o	o	o	불필요하거나 관리되지 않는 계정 제거	4	- 불필요한 계정 존재시 탈취될 위험이 증가하므로 불필요하거나 관리되지 않은 계정여부를 점검
4	o	o	o	비밀번호 복잡도 설정	5	- 비밀번호 복잡도가 낮을 경우 비밀번호 유추가 쉬워지므로 비밀번호 관리정책이 설정되어있는지 여부를 점검
5	o	o	o	비밀번호 변경 주기 충족 여부	4	- 비밀번호 유추 등의 위협으로 부터 보호하기 위해 비밀번호 변경주기 설정여부를 점검
6	o	o	o	이전 비밀번호 재사용 요구사항 충족 여부	3	- 이전 획득한 비밀번호 재사용 등의 위협에 대비하기 위해 이전 비밀번호 재사용 제한 설정 여부를 점검

ID	A	B	C	평가항목	위험도	상세설명
7	○	○	○	로그인 실패 횟수에 따른 접속 제한 설정	3	- 무작위 대입공격 등에 대비하기 위해 로그인 실패횟수에 따른 접속 제한 설정 여부를 점검
8		○		예외 사용자 목록 내 불필요한 사용자 제거	4	- 비인가자에 의한 시스템 무단 침입 할 수 있어, 예외 사용자 목록 내 불필요한 사용자 존재 여부를 점검
9	○	○	○	관리 용도 외 IP 접근 제한	4	- 비인가자에 의한 침해 위험이 발생할 수 있어, 관리 용도 외 IP 접근을 제한하는지 점검
10		○	○	하이퍼바이저 잠금 모드(Lockdown mode) 설정	4	- 비인가자에 의한 하이퍼바이저 설정변경, 수정 등 침해위험이 발생 할 수 있어, 잠금모드 설정 여부를 점검
11	○	○	○	시스템 사용 주의사항 출력	1	- 원격 로그인 시 시스템 사용 주의사항 등의 문구를 표시하는 설정 존재 여부를 점검
12	○	○	○	시간 동기화를 위한 NTP 설정	2	- NTP 동기화되지 않은경우, 위험발생시 로그 분석에 어려움 발생할 수 있어 NTP 설정을 통한 시간 동기화 여부를 점검
13	○	○	○	안전한 네트워크 모니터링 서비스 사용	3	- 모니터링 서비스 보안설정 미비시 상태정보가 유출될 수 있어, 프로토콜에 따라 안전한 보안설정 적용 여부를 점검
14	○	○		불필요한 시스템 관리 인터페이스 비활성화 여부	3	- 불필요한 인터페이스를 통해 시스템 정보 수집 등 위험이 발생될 수 있어, 불필요한 시스템 관리 인터페이스 비활성화 여부를 점검
15		○		신뢰할 수 없는 소프트웨어 패키지 설치 제한 여부	3	- 악의적인 소프트웨어가 임의 설치 될 수 있으므로, 신뢰 할 수 있는 소프트웨어 패키지를 설치하였는지 점검

ID	A	B	C	평가항목	위험도	상세설명
16	o	o		CEIP 기능 제한 여부	2	- CEIP(Customer Experience Improvement Program) 기능 활성화시 불필요한 정보가 유출될 수 있으므로, 비활성 여부를 점검
17	o	o		관리 홈페이지 세션 타임아웃 설정	3	- 비인가자에 의한 무단 사용을 방지하기 위해 세션 타임아웃 설정을 점검
18		o		불필요한 하이퍼바이저 관리도구 비활성화 여부	5	- 관리 플랫폼(vCenter 등)외 관리도구의 행위는 감사기록 등 관리가 어려울 수 있으므로, 불필요한 하이퍼바이저 관리도구 비활성화 여부를 점검
19		o		하이퍼바이저 관리도구 서비스 타임아웃 설정	4	- 비인가자에 의한 무단 사용 방지를 위해 관리도구 서비스 타임아웃 설정을 점검
20		o		하이퍼바이저 관리도구 세션 타임아웃 설정	4	- 비인가자에 의한 무단 사용을 방지하기 위해 세션 타임아웃 설정을 점검
21		o	o	콘솔 세션 타임아웃 설정	4	- 사용자 부재시, 비인가자에 의한 무단 사용을 방지하기 위해 콘솔 세션 타임아웃을 점검
22	o	o	o	원격 로그 서버 이용	3	- 원격 로그 서버를 이용하여 로그관리를 하지 않을 경우 침해에 따른 로그 유실 등이 발생 할 수 있으므로 원격 로그 서버 이용 여부를 점검
23	o	o	o	시스템 주요 이벤트 로그 설정	3	- 시스템 문제 발생시 이슈 파악을 위해 시스템, 가상머신 등 로그가 저장되도록 설정 되어있는지 점검
24		o	o	비휘발성 경로 내 로그 파일 저장	3	- 휘발성 경로에 로그 저장시 상실될 수 있으므로, 비휘발성 경로에 로그파일 저장여부 점검

ID	A	B	C	평가항목	위험도	상세설명
25	o	o	o	API 통신에 대한 보안 프로토콜 사용	3	- API 통신 구간 암호화 미적용시 요청 내용이 위변조 될 수 있으므로, 통신에 대한 보안프로토콜 적용 여부 점검
26		o	o	코어덤프 수집 기능 활성화 여부	3	- 시스템 장애 발생시 원인파악을 위해, 코어덤프 수집기능 활성화 여부 점검
27		o	o	가상머신의 장치 변경 제한 설정	3	- 비인가자에 의한 장치 설정 변경등을 방지하기 위한 설정 여부를 점검
28		o		가상머신의 장치 연결 제한 설정	3	- 비인가자에 의한 장치 임의 연결을 방지하기 위한 설정 여부 점검
29		o	o	가상머신의 불필요한 장치 제거	3	- 외부 장치는 잠재적 공격 통로가 될 수 있으므로, 불필요한 장치를 제거 여부를 점검
30		o		가상 디스크 축소 및 삭제 기능 제한	3	- 비인가자가 가상 디스크 축소 및 삭제 기능을 반복적으로 사용시, 서비스 거부가 발생할 수 있으므로 가상디스크 축소 및 삭제 기능 제한 설정 여부를 점검
31		o		가상머신 콘솔 클립보드 복사&붙여넣기 기능 비활성화 여부	3	- 파일 송수신 기록이 로그에 저장되지 않도록 클립보드를 활용한 가상머신 콘솔 복사 기능 비활성화 여부를 점검
32		o		가상머신 콘솔 드래그 앤 드롭 기능 비활성화 여부	3	- 파일 송수신 기록이 저장되지 않도록 가상머신의 드래그 앤 드롭 기능 비활성 여부를 점검
33		o		가상스위치 MAC 주소 변경 정책 비활성화 여부	3	- MAC 주소 변경을 통한 스푸핑 등 공격을 방지하지 위해 MAC주소 변경 정책 비활성화를 점검

ID	A	B	C	평가항목	위험도	상세설명
34		o	o	가상스위치 트래픽 복제 및 무차별 수신 방지	3	- 가상스위치를 통한 트래픽 유출 등으로 인한 위협을 방지하기 위해 트래픽 복제 및 무차별 수신관련 설정을 점검
35		o	o	가상스위치 위조 MAC 송신 차단 정책 설정	3	- MAC 스푸핑 등 공격을 방지하기 위해 위조 MAC 송신차단 기능을 설정하는지 점검

컨테이너 가상화 시스템

❖ 평가대상

A	B	C	D	E	F	G	H	I
k8s master	k8s worker	eks master	eks worker	aks master	aks worker	ocp master	ocp worker	docker

❖ 평가기준

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
1	o		o		o		o			불필요한 클러스터 관리자 역할 제거 여부	5	- 클러스터 관리자 권한은 모든 리소스 조작이 가능함에 따라 불필요한 클러스터 역할 부여 여부를 점검
2	o		o		o		o			Role(ClusterRole)의 과도한 권한 부여 제거 여부	4	- Role 또는 ClusterRole에 와일드카드(*)가 부여되어 있을 경우, 모든 리소스에 대한 권한이 부여되므로 와일드 카드 부여 여부를 점검
3	o		o		o		o			기본 서비스 계정(default) 사용 제거 여부	4	- 기본 서비스 계정이 리소스에 접근권한을 가질 수 있으므로, 불필요한 기본 서비스 계정 사용 유무를 점검
4	o						o			안전한 인증 방식 사용	5	- 취약점 인증방식은 인증정보 재사용 등 보안위협이 발생할 수 있으므로, 취약한 인증 방식 사용 여부를 점검
5	o						o			컨트롤러 별 서비스 계정 자격 증명 사용	3	- 컨트롤러간 위협이 서로 영향을 미치므로 각 컨트롤러의 서비스 계정 사용 관련 설정 여부를 점검

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
6	o		o		o		o			서비스 계정 토큰 자동 마운트 제한 설정 여부	3	- 서비스 계정 토큰이 자동 마운트 될 경우, 불필요한 권한 노출 등 위협이 발생할 수 있으므로 자동 마운트 제한 설정여부를 점검
7	o	o		o			o	o	o	시스템 주요 설정파일(디렉터리)의 권한 설정	3	- 시스템 주요 설정파일 권한 설정이 미흡할 경우 정보 노출 등 위협이 발생할 수 있으므로, 권한설정 적절성을 점검
8	o						o			서비스 바인딩 주소 제한 여부	4	- 컨트롤러 매니저, Scheduler에 무단 접근 가능시 클러스터 정보유출 등이 가능하므로, 사전 정의된 주소에서만 접근 가능한지 여부를 점검
9	o	o	o	o	o		o	o	o	시스템 주요 이벤트 로그 설정	3	- 시스템 주요 이벤트 로그 미설정시 보안 등 이슈발생시 원인파악이 어려우므로, 시스템 등 로그가 저장되도록 설정되어있는지를 점검
10	o	o					o	o		비휘발성 경로 내 로그 파일 저장	3	- 휘발성 경로에 로그 저장시, 시스템 재시작시 로그가 삭제 될 수 있으므로, 비휘발성 경로에 저장하는지 점검
11									o	원격 로그 서버 이용	3	- 원격 로그 서버를 이용하지 않을 경우, 로그 유실 등 위협이 발생할 수 있으므로 원격 로그 서버 이용여부를 점검
12	o	o	o				o		o	API 통신에 대한 보안 프로토콜 사용	3	- API 통신에 보안 프로토콜 미사용시 API 요청 내용이 위 변조 될 수 있으므로, 보안프로토콜 적용 여부를 점검

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
13	o	o	o	o						Anonymous 계정의 API 접속 제한 여부	3	- API 서버에 계정관련 부적절한 인증이 설정 되어있을 경우, 인증정보 탈취 등 위험이 발생 될 수 있으므로 API 접속제한 여부를 점검
14	o									API 요청 타임아웃 설정	3	- API 요청 타임아웃 제한시간이 크게 설정될 경우, 서비스 부하가 발생 할 수 있으므로 API 요청 타임아웃 설정 여부를 점검
15	o	o		o			o	o		API 사용에 대한 안전한 인증 모드 적용	3	- API 인증 미적용시 비인가자에 의한 시스템 설정변경 등 보안위험이 발생 될 수 있으므로, API 사용에 대한 인증 모드의 적절성을 점검
16	o						o			API 사용시 서비스 계정 토큰 검증 여부	3	- 서비스 계정 존재여부를 미검증시, 계정 삭제 후 인증토큰을 사용할 수 있으므로 서비스 계정 토큰 검증 여부를 점검
17		o		o				o		kubelet 읽기 전용 포트 비활성화 여부	4	- Kubelet 읽기 전용 포트 활성화시 정보유출 위험이 있으므로, 읽기 전용 포트 비활성화 여부를 점검
18		o		o				o		kubelet의 iptables 동기화 설정	4	- kubelet의 iptables 미동기화시 네트워크 트래픽이 예상치 못한 방식으로 라우팅 될 수 있으므로, 동기화 설정 여부를 점검
19									o	컨테이너 런타임 데몬의 관리자 권한 실행 제한 여부	4	- Docker 데몬이 루트로 실행시 권한문제로 인하여 호스트 시스템에 영향이 미칠수 있으므로, 컨테이너 런타임 데몬의 Non-root 사용가 실행 여부를 점검

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
20									○	실험적 기능 비활성화 여부	3	- 실험적 기능 활성화시 시스템 안전성에 영향을 미칠 수 있으므로, 비활성화 여부를 점검
21									○	데몬의 사용자 영역(userland) 프록시 사용 제한 여부	3	- 데몬의 사용자 영역 프록시 사용 미제한시 시스템 부하 등 보안 위협이 발생할 수 있으므로 프록시 사용여부를 점검
22	○	○		○				○	○	○ 레지스트리 연결 구간에 대한 보안 프로토콜 사용	2	- 레지스트리 통신구간 암호화 미적용시 중간자 공격등이 발생 될 수 있으므로 연결 구간 암호화 통신 여부를 점검
23									○	사용자 정의 네트워크 사용 여부	3	- 기본 네트워크 인터페이스 사용시 ARP Spoofing 등 공격에 취약할 수 있으므로, 사용자 정의 네트워크 사용 여부를 점검
24	○		○		○			○		○ 컨테이너간 불필요한 통신 제한 설정	3	- 컨테이너간 불필요한 통신 제한 미설정시 취약한 컨테이너를 통해 공격이 전파될 가능성이 있으므로, 통신 제한 설정 여부를 점검
25	○									불필요한 프로파일링 기능 비활성화 여부	2	- 프로파일링 기능 활성화시 시스템 정보 유출이 될 수 있으므로, 프로파일링 기능 비활성화 여부를 점검
26	○		○		○		○		○	컨테이너의 privileged 플래그 제거	5	- privileged 플래그 미제거시 컨테이너에서 호스트 시스템에 접근 할 수 있는 보안 위협이 발생할 수 있으므로, 플래그 제거 여부를 점검

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
27	o		o		o		o			과도한 커널 접근 권한 제거	4	- 과도한 커널 접근권한 부여시, 권한문제가 발생 할 수 있으므로 과도한 접근권한 부여여부를 점검
28	o		o		o		o			불필요한 커널 접근 권한 제거	4	- 불필요한 커널 접근권한이 있는경우 컨테이너가 높은 권한을 가질 수 있으므로, 불필요한 접근 권한 제거여부를 점검
29	o		o		o		o		o	컨테이너의 권한 통제 설정	4	- 컨테이너를 통한 권한상승 시도 방지를 위해, 컨테이너 권한 통제 설정 여부를 점검
30	o								o	컨테이너 및 POD에 seccomp 활성화 및 적용	5	- seccomp 사용시 악의적인 시스템 호출을 제한 할 수 있으므로, seccomp 활성화 및 적용 여부를 점검
31	o		o		o		o		o	컨테이너의 관리자 권한 실행 제한	4	- 컨테이너가 관리자 권한으로 실행시, 컨테이너 내부에서의 공격이 호스트 시스템이 영향을 미칠 수 있으므로, 일반 사용자 계정으로 컨테이너 실행여부를 점검
32									o	컨테이너의 상태 보존 설정	2	- 컨테이너 재시작시 가용성 확보를 위해, 컨테이너의 상태 보존 옵션 설정 여부를 점검
33	o		o		o		o		o	컨테이너 재시작 정책 설정	2	- 장애 발생 시 시스템이 복구되지 않아 서비스 가용성에 영향을 끼칠 수 있으므로 재시작 정책 설정 여부를 점검
34									o	컨테이너 HEALTHCHECK	2	- 서비스 가용성 확보를 위해 이미지 내 또는 컨테이너 실행 시 HEALTHCHECK 명령 포함여부를 확인

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
35	o		o		o		o		o	컨테이너 내 시스템 디렉터리 마운트 제거	4	- 디렉토리 마운트 권한설정 오류시 컨테이너에서 호스트 시스템으로 침해가 발생할 수 있으므로, 시스템 디렉터리 마운트 모두를 점검
36	o						o		o	컨테이너 내 CRI socket 볼륨 마운트 제거	4	- CRI socket 볼륨이 마운트된 컨테이너는 컨테이너 간 침입 등 위험이 발생 될 수 있으므로, 컨테이너 내 CRI socket 볼륨 마운트 제거 여부를 확인
37	o		o		o		o		o	읽기 전용 모드로 컨테이너 루트 파일 시스템 마운트 여부	3	- 읽기 전용 모드로 컨테이너 루트 파일 시스템 마운트시 컨테이너 무결성 유지할 수 있으므로, 읽기 전용 모드 여부를 점검
38	o		o		o		o		o	마운트 전파 모드(Mount Propagation Mode) 공유 설정 제한 여부	3	- 마운트 전파 모드가 공유로 설정시 컨테이너간 불필요한 정보가 전파될 수 있으므로, 마운트 전파모드 공유 설정 여부를 점검
39	o		o		o		o		o	컨테이너의 불필요한 외부 장치 제거	3	- 컨테이너에 호스트 장치 연결된 경우, 서로 예측하지 못한 위험을 발생 시킬 수 있으므로, 불필요한 외부장치 제거 여부를 확인
40		o		o					o o	불필요한 AUFS 스토리지 드라이버 제거	3	- AUFS 스토리지 드라이버를 사용할 경우, 안정성 문제 등을 일으킬 수 있으므로, AUFS 스토리지를 불필요한 사용 여부를 점검

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
41									○	호스트의 사용자 네임스페이스 공유 제한 설정	3	- 컨테이너 내부에서 실행되는 프로세스가 호스트 시스템에 불필요한 권한을 갖지 않게 하기 위해, 호스트의 사용자 네임스페이스를 공유하지 않도록 설정되어 있는지 여부를 점검
42	○		○		○		○		○	컨테이너의 호스트 PID 네임스페이스 공유 제한 설정	3	- PID 네임스페이스 공유시 컨테이너 내 프로세스가 호스트 시스템 프로세스를 조작할 수 있으므로, PID 네임스페이스 공유 여부를 점검
43	○		○		○		○		○	컨테이너의 호스트 IPC 네임스페이스 공유 제한 설정	3	- IPC 네임스페이스 공유시 컨테이너 내 프로세스가 호스트 시스템의 모든 IPC를 조작 할 수 있으므로, IPC 네임스페이스 공유 여부를 점검
44	○		○		○		○		○	컨테이너의 호스트 네트워크 네임스페이스 공유 제한 설정	3	- 컨테이너 네트워크 네임스페이스 공유 옵션 설정시, 네트워크 스니핑 등 보안위협이 발생 될 수 있으므로, 네트워크 네임스페이스 공유 옵션 설정 여부를 점검
45	○						○		○	컨테이너의 호스트 UTS 네임스페이스 공유 제한 설정	3	- UTS 네임스페이스 공유 옵션이 설정시, 컨테이너에 의한 서비스 중단 등이 발생할 수 있으므로 UTS 네임스페이스 공유 옵션 설정여부를 점검
46	○		○		○		○			불필요한 HostPort 제거	4	- 불필요한 HostPort 미제거시 외부로부터 직접 접근이 가능함에따라 보안위협이 발생할 수 있으므로, 불필요한 HostPort 사용 여부를 점검

ID	A	B	C	D	E	F	G	H	I	평가항목	위험도	상세설명
47	o		o		o		o		o	컨테이너의 메모리 사용 제한 설정	2	- 컨테이너 메모리 사용 제한 미설정시 호스트 서버의 리소스가 고갈 될 수 있으므로, 메모리 사용제한 설정 여부를 점검
48		o							o	cgroup 사용 설정	2	- 컨테이너의 과도한 리소스 사용을 방지하기 위해 cgroup 사용여부를 점검
49									o	PID 제한 설정	2	- PID를 제한하지 않을 경우 자원고갈 등 문제가 발생될 수 있으므로 최대 프로세스 개수 제한 여부를 점검
50									o	Ulimit 구성의 적절성	2	- 하나의 컨테이너가 많은 자원 소비시 호스트 시스템 가용성 문제가 발생하므로, 컨테이너 자원 제한 여부를 점검

웹·모바일·HTS 애플리케이션

❖ 평가기준

ID	평가항목	위험도	상세설명
1	[전자금융] 거래 인증수단 검증	5	○비정상 인증수단 차단 및 인증 유효시간 준수 여부 등 거래 인증 프로세스 적절성 점검
2	[전자금융] 거래정보 무결성 검증	5	○거래 전 과정에서 데이터의 임의 변조를 차단하고, 전자서명 및 단계별 검증을 통해 거래정보의 신뢰성 확보 여부 점검
3	[전자금융] 거래정보 재사용 방지	5	○전자금융거래 이용시 기처리된 거래 전문의 재사용이 방지되는지 점검
4	[전자금융] 거래시 소유주 검증	5	○전자금융거래시 이용자 권한 외에 타인의 거래 정보에 대한 조회 및 변조 시도를 차단하는지 점검
5	[전자금융] 비밀번호 변경 시 본인확인 절차 수행	5	○비밀번호 변경시 본인확인 절차 수행 여부 점검
6	[전자금융] 비밀번호 변경 시 이전 비밀번호 재사용 방지	5	○비밀번호 변경시 과거 이용 비밀번호 재사용 방지 여부 점검
7	[전자금융] OS 변조 탐지 기능 적용	5	○변조된 OS를 통한 서비스 이용 방지 여부 점검
8	[전자금융] 악성코드 방지	5	○전자금융서비스 이용시 악성코드 차단 및 탐지 프로그램 동작 여부 점검
9	[전자금융] 보안프로그램 동작 여부	5	○보안프로그램 동작 여부 점검
10	[전자금융] 보안프로그램 임의해제 방지	5	○보안프로그램 임의 해제 가능 여부 및 해제 시 이용자 주의 프로세스 유무 점검

ID	평가항목	위험도	상세설명
11	[전자금융] 프로그램 실행 명령줄(Command Line) 내 중요정보 평문 노출 방지	5	○프로그램 실행 명령줄 내 중요정보 평문 노출 여부 점검
12	[전자금융] HTS 구동시 실행 파라미터 재사용 방지	5	○실행 파라미터 재사용을 통한 타인의 HTS 계정 접근 가능성 점검
13	[전자금융] 이용자 입력정보 보호	4	○거래정보 입력 보호 범위의 일관성을 검증하고, 입력단계 위협 대응을 위한 절차 및 방안 유무 점검
14	[전자금융] 프로그램 무결성 검증	5	○변조프로그램 이용시 정상실행 가능 여부 점검
15	[전자금융] 소스코드 난독화 적용	4	○디컴파일(DeComplie) 기술을 통한 소스코드 분석 시 소스코드(또는 실행파일)의 난독화 여부 점검
16	[전자금융] 디버깅 탐지기능 적용	4	○디버깅을 통한 역분석을 방지하기 위한 안티디버깅 적용 여부 점검
17	[전자금융] 보안프로그램 구동시 최신 업데이트 수행	4	○보안프로그램 최신 버전 유지 여부 점검
18	[전자금융] 접근매체 발급 시 실명확인 수행	5	○접근매체 발급 시 실명확인 수행 여부를 점검
19	SQL Injection	5	○SQL 질의문에 들어가는 매개변수 변조를 통해 비정상 질의 가능 여부 점검
20	악성파일 업로드	5	○웹셀 등 악성파일 업로드 및 실행 가능 여부 점검
21	부적절한 이용자 인가	5	○사용자별 접근 권한 검증 로직이 부재하여, 파라미터 조작 등을 통해 타인의 민감

ID	평가항목	위험도	상세설명
			정보를 조회·수정하거나 관리자 권한을 획득할 수 있는지 점검
22	이용자 인증정보 재사용 방지	5	○ 탈취된 인증정보(전자서명값 등)를 재사용한 이용자 인증이 가능한지 점검
23	고정된 인증정보 이용 방지	5	○ 사용자 인증을 위해 가변적인 인증코드를 생성하고 있는지 점검
24	유추 가능한 인증정보 이용 방지	5	○ 인증 정보 등록 및 변경 시, 제3자가 쉽게 유추할 수 없도록 엄격한 복잡도와 적절성 규칙이 적용되는지 점검
25	유추 가능한 초기화 비밀번호 이용 방지	5	○ 비밀번호 찾기·초기화 시 생성되는 비밀번호의 규칙성을 분석하여 타인 계정 탈취 가능성을 점검
26	단말기 내 중요정보 저장 방지	5	○ 앱 관련 폴더 및 외부 저장소 내 파일에 개인·금융 등 중요 정보가 저장되어 있는지 점검
27	메모리 내 중요정보 노출 방지	5	○ 메모리 덤프를 통해 앱 실행 중 사용자 중요 정보가 암호화되지 않은 평문 상태로 노출되는지 점검
28	파일 다운로드	5	○ 파일 다운로드 경로 조작을 통해 소스코드나 설정 파일 등 서버 내부의 주요 파일이 유출되는지 점검
29	외부사이트에 의한 시스템 운영정보 노출 여부	5	○ 검색엔진 및 외부 사이트 분석 도구를 활용하여 대상과 관련된 중요 정보가 공개적으로 노출되어 있는지 점검
30	유추 가능한 세션ID	5	○ 세션 ID의 복잡성을 분석하여 단순 증분이나 규칙성 등 무차별 대입 공격에 취약한 설정인지 점검
31	쿠키변조	5	○ 쿠키 내 계정·권한 정보의 조작을 통해 타인의 권한을 탈취하거나 중요 정보를 유출할 수 있는지 점검

ID	평가항목	위험도	상세설명
32	운영체제 명령실행	5	○ 서버 명령 실행 인터페이스를 통해 지정된 명령 외에 관리자 권한 등 임의의 명령을 실행할 수 있는지 점검
33	XML 외부객체 공격 (XXE)	5	○ XML 입력값 검증 미흡을 악용하여 서버의 내부 자원에 접근하거나 외부 명령을 실행할 수 있는지 점검
34	리다이렉트 기능을 이용한 피싱 공격	4	○ 리다이렉트 시 대상 URL 검증 누락을 악용하여 사용자를 임의의 악성 페이지로 유도할 수 있는지 점검
35	LDAP Injection	5	○ LDAP 쿼리 생성 시 입력값 검증 미흡을 악용하여 데이터 유출이나 임의 명령 실행이 가능한지 점검
36	SSI Injection	5	○ 사용자 입력값에 부적절한 명령문을 삽입하여 서버 측에서 임의의 스크립트나 명령이 실행되는지 점검
37	불충분한 이용자 인증	4	○ 중요 기능 및 경로 접근 시 인증 절차의 적절성을 확인하고, 단계별 인증(플로우) 우회 가능 여부를 점검
38	화면 내 중요정보 평문노출 방지	5	○ 화면상 중요 정보의 평문 노출 여부와 캡처 방지 등 보안 설정이 적용되었는지 점검
39	무제한 요청 차단	5	○ 리소스 고갈이나 비용 발생을 유발하는 기능(SMS, 인증 등)에 대한 무분별한 반복 호출 가능 여부를 점검
40	버퍼오버플로우 (Buffer Overflow Attack)	5	○ 경계 검사를 하지 않는 취약한 함수 사용으로 인한 버퍼 오버플로우 및 프로그램 흐름 조작 가능성을 점검

ID	평가항목	위험도	상세설명
41	포맷스트링 (Format String Attack)	5	○포맷 스트링(sprintf 등) 인자값 검증 미흡을 악용하여 메모리 데이터를 변조하거나 임의 영역에 접근할 수 있는지 점검
42	단말기 브라우저 영역 내에서의 중요정보 노출 방지	5	○브라우저 개발자 도구(DOM, HTML) 및 스크립트 영역 내 중요 정보의 평문 노출 여부를 점검
43	앱 소스코드 내 운영정보 노출 방지	5	○앱 소스코드를 디컴파일 및 역분석하여 서버 계정 정보나 고정된 암호키 등 운영 정보가 노출되는지 점검
44	화면 강제실행에 의한 인증단계 우회 방지	5	○인텐트(Intent) 호출이나 인증 설정 파일 조작을 통해 정상적인 인증 절차를 건너뛰고 서비스에 접근할 수 있는지 점검
45	크로스사이트 요청변조 (CSRF)	4	○사용자 입력값(게시글, 파일 등)에 악성 스크립트를 삽입하여 이를 열람하는 타 사용자의 세션이나 권한을 탈취할 수 있는지 점검
46	디렉토리 목록 노출 방지	4	○서버 설정 미흡으로 인해 브라우저상에서 디렉토리 내부 파일 목록이 그대로 노출되는지 점검
47	서버 인증서 무결성 검증	3	○서버 인증서의 유효기간, 발급 기관, 도메인 일치 여부 등을 확인하여 통신 무결성 및 사용자 신뢰성 확보 여부를 점검
48	시스템 운영정보 노출 방지	4	○에러 페이지나 응답 데이터 내에 서버의 절대 경로, 소프트웨어 버전 등 시스템 내부 정보가 포함되어 노출되는지 점검
49	인증 오류 횟수 제한기능 제공	3	○비밀번호 무작위 대입 공격(Brute-force) 시도를 차단하기 위해, 일정 횟수 이상 인증 실패 시 서비스 이용을 제한하는지 점검
50	세션종료 설정	4	○사용자가 일정 시간 동안 활동이 없을 경우 세션을 자동으로 종료(Timeout)하여

ID	평가항목	위험도	상세설명
			계정 탈취 위험을 방지하고 있는지 점검
51	취약한 HTTPS 프로토콜 이용 제한	3	○취약한 버전의 암호 프로토콜(SSL 3.0 이하, TLS 1.2 미만) 지원 여부를 점검하여 통신 과정에서의 데이터 유출 위험을 차단
52	취약한 HTTPS 암호 알고리즘 이용	3	○취약한 암호 알고리즘(DES, RC4 등)이나 짧은 키 길이를 사용하여 통신 내용이 복호화될 위험이 있는지 점검
53	취약한 HTTPS 컴포넌트 제거	3	○HTTPS 확장 모듈 및 OpenSSL의 알려진 취약점(Heartbleed, CCS Injection 등) 존재 여부를 점검
54	취약한 HTTPS 재협상 차단	2	○TLS 1.0 이하 버전에서 클라이언트 주도의 HTTPS 재협상(Renegotiation) 기능이 활성화되어 통신 내용이 유출될 수 있는지 점검
55	불필요한 웹 메서드 차단	1	○서버 운영에 불필요한 HTTP 메서드(PUT, DELETE, TRACE 등)를 활성화하여 파일 변조나 정보 유출의 위험이 있는지 점검
56	관리자 페이지 접근 통제 여부	4	○비정상적인 경로 추측이나 권한 검증 미흡을 통해 일반 사용자가 관리자 전용 페이지에 접속할 수 있는지 점검
57	불필요한 파일 노출 여부	4	○개발 및 테스트 과정에서 남겨진 불필요한 파일이나 기능이 실 운영 환경에 방치되어 공격의 통로로 악용되는지 점검
58	크로스 사이트 스크립팅 (XSS)	4	○사용자가 입력한 악성 스크립트가 데이터베이스에 저장된 후, 이를 열람하는 다른 사용자의 브라우저나 웹뷰에서 실행되는지 점검
59	디버그 로그 내 중요정보 노출 방지	5	○애플리케이션 실행 중 출력되는 시스템 로그에 비밀번호, 카드번호 등 중요 정보가 평문으로 남는지 점검

ID	평가항목	위험도	상세설명
60	백그라운드 화면 보호	3	○ 애플리케이션이 백그라운드로 전환될 때 생성되는 스냅샷(미리보기 이미지)에 중요 정보(계좌번호, 잔액, 개인정보 등)가 그대로 노출되는지 점검
61	서버 사이드 요청 위조 (SSRF)	4	○ 서버 측에서 외부의 요청을 받아 내부 네트워크의 자원에 대신 접근하는 특성을 악용하여, 공격자가 직접 접근할 수 없는 내부 서버와 통신하거나 정보를 탈취하는지 점검
62	세션정보 재사용 제한 여부	3	○ 세션 ID나 액세스 토큰을 탈취하여 다른 네트워크나 단말기 환경에서 재사용했을 때, 별도의 검증 없이 권한이 도용되는지 점검
63	인증수단 소유자 검증	5	○ 본인 확인 및 인증 수단 등록 과정에서 타인의 정보(인증서, 전화번호, 계좌 등)를 도용하여 불법적으로 인증을 통과할 수 있는지 점검
64	모바일 DeepLink 도용 제한 여부	5	○ 공격자가 조작한 URI를 통해 앱 내 특정 화면을 강제 호출하거나, 인증 우회 및 악성 코드를 실행할 수 있는지 점검
65	통신구간 암호화 적용	5	○ 이용자 개인정보, 금융 거래 정보, 인증 정보 등 민감한 데이터 전송 시 암호화 통신 프로토콜이 적용되어 있는지 점검
66	서버 사이드 템플릿 인젝션(SSTI)	5	○ 사용자 입력값이 서버 측 템플릿 엔진에 의해 해석되어 서버 내 임의 코드가 실행되는지 점검

2026년 전자금융기반시설
보안 취약점 평가기준 안내서 (제2026-1호)

발 행 : 2026년 2월

발행인 : 박 상 원

발행처 : 금융보안원, 보안평가부 (보안평가총괄팀)

주 소 : 경기도 용인시 수지구 대지로 132

<비 매 품>

본 안내서 내용의 무단전재를 금하며, 가공 인용할 때에는 반드시 금융보안원
「전자금융기반시설 보안 취약점 평가기준 안내서」라고 밝혀 주시기 바랍니다.

- 상기 내용과 관련하여 궁금한 사항은 이메일(fsat@fsec.or.kr) 또는 전화(02-3495-9595)로 문의하시기 바랍니다.